

Cyber Security & Ethical Hacking

Student Name : Sakshi Maruti Nalawade.

Institute : Fortune cloud Technologies, Pune

Lab Environment : Kali Linux

INDEX	
	Title
1.	Objective
2.	Tools
3.	Environment
4.	Methodology
5.	Results and Observations

Project Objectives

- Develop a dictionary generator for password testing.
- Extract password hashes from Linux shadow files and Windows SAM database (ethical environment only).
- Build a brute-force simulation engine to test password robustness.
- Analyse password strength based on complexity, entropy, and predictability.
- Generate a detailed audit report on password vulnerabilities and mitigation steps.

Tools & Technologies Used

Programming Languages:

- Python (recommended)
- Bash (optional)

Modules/Tools Used:

- hashlib (hashing operations)
- crypt / passlib (Linux password hash processing)
- reg.exe (Windows hive export)
- Samdump2 (hash extraction)
- John the Ripper / Hashcat (optional reference tools, not mandatory)

Documentation Tools:

- Word / Google Docs
- word (flowcharts and architecture diagrams)

Task 1- Footprinting, Reconnaissance & Scanning Report

Objectives

You will:

1. Perform Footprinting
2. Perform Reconnaissance
3. Scan Network & Ports
4. Detect Services & OS
5. Identify Possible Vulnerabilities
6. Create Report with Screenshots

Tools Used

Tool	Purpose
WHOIS	Domain information
nslookup	DNS lookup
theHarvester	Email & subdomain gathering
recon-ng	Recon framework
Nmap	Network scanning

Step 1: Open Kali Linux Terminal

Update system:

sudo apt update && sudo apt upgrade -y

```

(sakshi@kali)-[~]
└─$ sudo apt update && sudo apt upgrade -y
[sudo] password for sakshi:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.9 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [116 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [258 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [910 kB]
Fetched 75.3 MB in 4min 35s (274 kB/s)
2185 packages can be upgraded. Run 'apt list --upgradable' to see them.
The following packages were automatically installed and are no longer required:
amass-common          libgirepository-1.0-1  libspnbase3t64        python3-kismetcapturetlad
curlftpfs             libgpgme11t64         libsqlcipher1         python3-kismetcapturetlam
firmware-ti-connectivity libgpgmepp6t64        libswscale8           python3-multipart
gir1.2-girepository-2.0 libhdf4-0-alt         libteamctl0           python3-packaging-whl
libarmadillo14        libinstpatch-1.0-2   libtheora0            python3-pluginbase
libaudio2             libjs-jquery-ui       libtsk19t64          python3-protobuf
libavc1394-0          libjs-underscore     libudfread0           python3-pyinstaller-hooks-contrib
libavfilter10         libmongoc-1.0-0t64   libunibreak6         python3-pysmi
libavformat61         libmupdf25.1         libvdpau-va-gl1      python3-pysnmp4
libblosc2-4          libnet1              libwirehawk18        python3-terminaltables
libbluray2            libogdi4.1           libwiretap15         python3-wheel-whl
libbson-1.0-0t64     libplacebo349        libwsutil16          python3-xlrd
libconfig-inifiles-perl libpocketsphinx3     mesa-vidpau-drivers  python3-xlutils
libcrypt-dev          libportmidi0         openjdk-21-jre       python3-xlwt
libdisplay-info2     libpostproc58        openjdk-21-jre-headless python3-yaswfp
libdlt2              libqt5ct-common1.8   pocketsphinx-en-us   python3-zombie-imp
libfuse2t64          libradare2-5.0.0t64  python3-bluepy       ruby-unf-ext
libgav1-1            librubberband2       python3-click-plugins samba-ad-dc

```

PART 1 — FOOTPRINTING

1. WHOIS Lookup

The whois command is commonly used for domain information gathering and reconnaissance in cybersecurity.

WHOIS provides:

- Domain owner details
- Registrar information
- Name servers
- Registration dates

Command:

whois openai.com

```

(sakshi@kali)-[~]
$ whois openai.com
Domain Name: OPENAI.COM
Registry Domain ID: 764064142_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Updated Date: 2024-10-17T22:20:04Z
Creation Date: 2007-01-19T19:28:24Z
Registry Expiry Date: 2029-01-19T19:28:24Z
Registrar: MarkMonitor Inc.
Registrar IANA ID: 292
Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
Registrar Abuse Contact Phone: +1.2086851750
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Domain Status: serverDeleteProhibited https://icann.org/epp#serverDeleteProhibited
Domain Status: serverTransferProhibited https://icann.org/epp#serverTransferProhibited
Domain Status: serverUpdateProhibited https://icann.org/epp#serverUpdateProhibited
Name Server: NS1-02.AZURE-DNS.COM
Name Server: NS2-02.AZURE-DNS.NET
Name Server: NS3-02.AZURE-DNS.ORG
Name Server: NS4-02.AZURE-DNS.INFO
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-16T10:03:37Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

```

Capture:

- WHOIS result
- Registrar info
- Name servers

2. NSLOOKUP

nslookup retrieves DNS information.

Used for:

- IP address lookup
- DNS server lookup
- MX records
- Name servers

Command:

nslookup microsoft.com

```

(sakshi@kali)-[~]
$ nslookup microsoft.com
Server:          192.168.137.2
Address:         192.168.137.2#53

Non-authoritative answer:
Name:   microsoft.com
Address: 150.171.110.82
Name:   microsoft.com
Address: 2620:1ec:46::68
Name:   microsoft.com
Address: 2620:1ec:bdf::68

```

Capture:

- Server IP
- Domain IP address

MX Record Lookup:

Mail server records.

nslookup -query=mx gmail.com OR nslookup -type=mx gmail.com

```
(sakshi@kali)-[~]
$ nslookup -type=mx gmail.com
Server:      192.168.137.2
Address:     192.168.137.2#53

Non-authoritative answer:
gmail.com    mail exchanger = 10 alt1.gmail-smtp-in.l.google.com.
gmail.com    mail exchanger = 40 alt4.gmail-smtp-in.l.google.com.
gmail.com    mail exchanger = 30 alt3.gmail-smtp-in.l.google.com.
gmail.com    mail exchanger = 5 gmail-smtp-in.l.google.com.
gmail.com    mail exchanger = 20 alt2.gmail-smtp-in.l.google.com.

Authoritative answers can be found from:
```

Name Server Lookup:

Mail server records.

nslookup -query=ns example.com

```
(sakshi@kali)-[~]
$ nslookup -query=ns wikipedia.org
Server:      192.168.137.2
Address:     192.168.137.2#53

Non-authoritative answer:
wikipedia.org nameserver = ns0.wikimedia.org.
wikipedia.org nameserver = ns1.wikimedia.org.
wikipedia.org nameserver = ns2.wikimedia.org.

Authoritative answers can be found from:
```

3. theHarvester

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

theHarvester collects:

- Emails
- Subdomains
- Hosts
- Employee names

Basic Scan

theHarvester -d Microsoft.com -b bing
-d Target domain

Purpose:

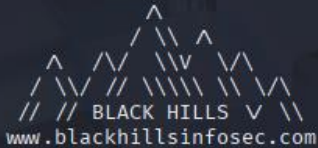
More Advanced Scan

theHarvester -d example.com -b all

More Advanced Scan

theHarvester -d example.com -b all


```
(sakshi@kali)-[~]
$ recon-ng
[*] Version check disabled.
```



```
Sponsored by ...

PRATISEC
www.practisec.com

[recon-ng v5.1.2, Tim Tomes (@lanmaster53)]
```

Workspace Creation

workspaces create EHF-B2

```
[recon-ng][default] > workspaces create EHF-B2
[recon-ng][EHF-B2] > workspaces list
```

Workspaces	Modified
EHF-B2	2026-05-17 05:32:27
default	2026-05-17 05:28:23

Add Domain

add domains example.com

```
[recon-ng][EHF-B2] > db insert domains
domain (TEXT): certifiedhacker.com Actions Edit View Help
notes (TEXT): This is My Domain
[*] 1 rows affected.
[recon-ng][EHF-B2] > show domains
```

rowid	domain	notes	module
1	certifiedhacker.com	This is My Domain	user_defined

Load Module

modules load recon/domains-hosts/bing_domain_web

```
[*] 1 rows returned
[recon-ng][EHF-B2] > modules search hackertarget
[*] Searching installed modules for 'hackertarget'...

Recon
-----
recon/domains-hosts/hackertarget

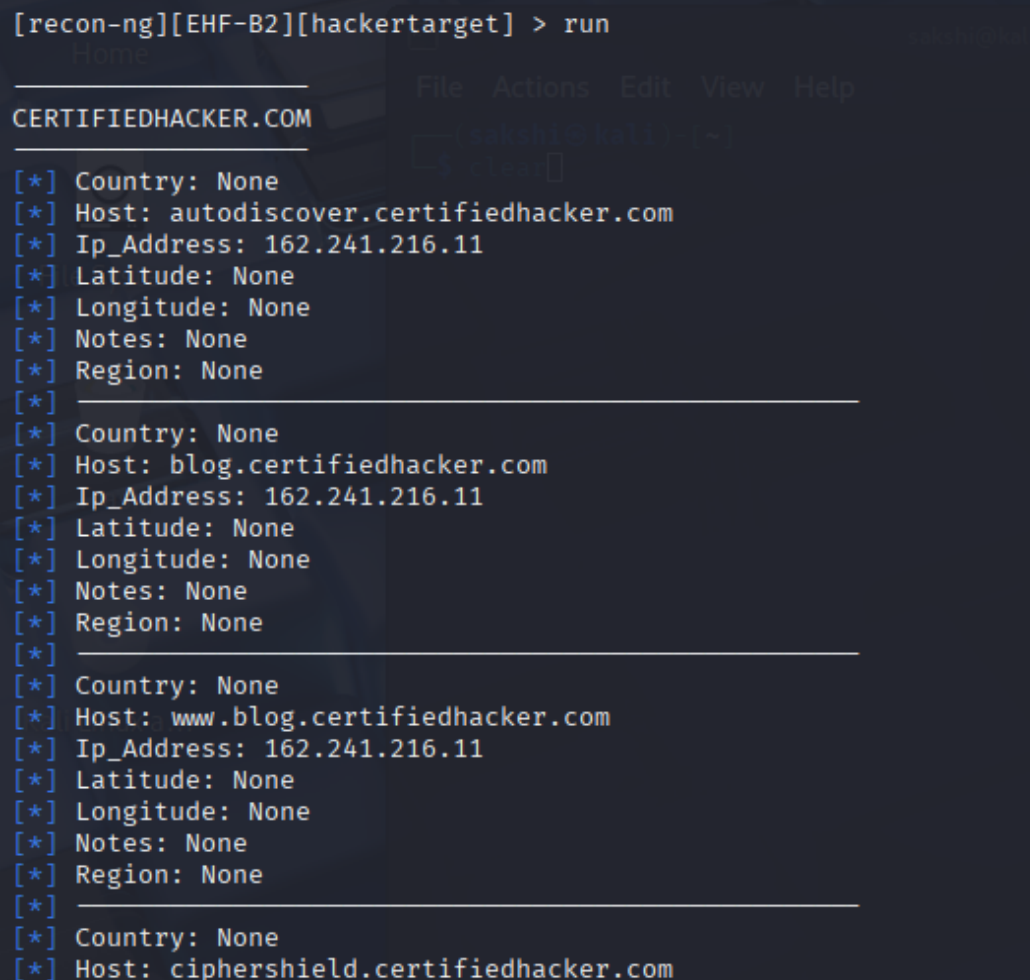
[recon-ng][EHF-B2] > modules load recon/domains-hosts/hackertarget
[recon-ng][EHF-B2][hackertarget] > options set SOURCE certifiedhacker.com
SOURCE ⇒ certifiedhacker.com
[recon-ng][EHF-B2][hackertarget] > options list
```

Name	Current Value	Required	Description
SOURCE	certifiedhacker.com	yes	source of input (see 'info' for details)

Run Module

Run

```
[recon-ng][EHF-B2][hackertarget] > run
```



```
[*] Country: None
[*] Host: autodiscover.certifiedhacker.com
[*] Ip_Address: 162.241.216.11
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: blog.certifiedhacker.com
[*] Ip_Address: 162.241.216.11
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: www.blog.certifiedhacker.com
[*] Ip_Address: 162.241.216.11
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: ciphershield.certifiedhacker.com
```

Show Results

show hosts

```
38 total (0 new) hosts found.
recon-ng][EHF-B2][hackertarget] > show hosts
```

rowid	host	ip_address	region	country	latitude	longitude	notes	module
1	autodiscover.certifiedhacker.com	162.241.216.11						hackertarget
2	blog.certifiedhacker.com	162.241.216.11						hackertarget
3	www.blog.certifiedhacker.com	162.241.216.11						hackertarget
4	ciphershield.certifiedhacker.com	66.235.200.145						hackertarget
5	www.ciphershield.certifiedhacker.com	162.241.216.11						hackertarget
6	cpanel.certifiedhacker.com	162.241.216.11						hackertarget
7	demo.certifiedhacker.com	162.241.216.11						hackertarget
8	autodiscover.demo.certifiedhacker.com	162.241.216.11						hackertarget
9	mail.demo.certifiedhacker.com	162.241.216.11						hackertarget
10	webdisk.demo.certifiedhacker.com	162.241.216.11						hackertarget
11	www.demo.certifiedhacker.com	162.241.216.11						hackertarget
12	events.certifiedhacker.com	162.241.216.11						hackertarget
13	www.events.certifiedhacker.com	162.241.216.11						hackertarget
14	fleet.certifiedhacker.com	162.241.216.11						hackertarget
15	www.fleet.certifiedhacker.com	162.241.216.11						hackertarget
16	ftp.certifiedhacker.com	162.241.216.11						hackertarget
17	iam.certifiedhacker.com	162.241.216.11						hackertarget
18	www.iam.certifiedhacker.com	162.241.216.11						hackertarget
19	itf.certifiedhacker.com	162.241.216.11						hackertarget
20	www.itf.certifiedhacker.com	162.241.216.11						hackertarget
21	mail.certifiedhacker.com	162.241.216.11						hackertarget
22	news.certifiedhacker.com	162.241.216.11						hackertarget
23	www.news.certifiedhacker.com	162.241.216.11						hackertarget
24	notifications.certifiedhacker.com	162.241.216.11						hackertarget
25	www.notifications.certifiedhacker.com	162.241.216.11						hackertarget
26	pstn.certifiedhacker.com	162.241.216.11						hackertarget
27	www.pstn.certifiedhacker.com	162.241.216.11						hackertarget
28	sftp.certifiedhacker.com	162.241.216.11						hackertarget
29	www.sftp.certifiedhacker.com	162.241.216.11						hackertarget
30	soc.certifiedhacker.com	162.241.216.11						hackertarget
31	www.soc.certifiedhacker.com	162.241.216.11						hackertarget
32	trustcenter.certifiedhacker.com	162.241.216.11						hackertarget
33	www.trustcenter.certifiedhacker.com	162.241.216.11						hackertarget
34	webdisk.certifiedhacker.com	162.241.216.11						hackertarget
35	webmail.certifiedhacker.com	162.241.216.11						hackertarget
36	website-215f0f34.certifiedhacker.com	162.241.216.11						hackertarget
37	www.website-215f0f34.certifiedhacker.com	162.241.216.11						hackertarget
38	www.certifiedhacker.com	162.241.216.11						hackertarget

```
38 rows returned
recon-ng][EHF-B2][hackertarget] > █
```

Capture:

- Loaded module
- Hosts discovered
- Workspace

PART 2 — SCANNING WITH NMAP

Nmap performs:

- Host discovery
- Port scanning
- Service detection
- OS detection
- Vulnerability scanning

1. Host Discovery

Ping Scan

nmap -sn 192.168.137.129/24

-sn Ping scan only

/24 Entire subnet

```

(sakshi@kali)-[~]
$ nmap -sn 192.168.137.129/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:44 CDT
Nmap scan report for 192.168.137.2
Host is up (0.00034s latency).
MAC Address: 00:50:56:EF:5E:C5 (VMware)
Nmap scan report for 192.168.137.254
Host is up (0.056s latency).
MAC Address: 00:50:56:E0:10:B3 (VMware)
Nmap scan report for 192.168.137.129
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.42 seconds

```

Capture:

- Live hosts

2. Port Scanning

Scan Common Ports

nmap 192.168.1.10

```

(sakshi@kali)-[~]
$ nmap 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:49 CDT
Nmap scan report for 192.168.137.129
Host is up (0.0000040s latency).
All 1000 scanned ports on 192.168.137.129 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds

```

nmap -p 8080,443 192.168.137.129

```

(sakshi@kali)-[~]
$ nmap -p 8080,443 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:49 CDT
Nmap scan report for 192.168.137.129
Host is up (0.000032s latency).

PORT      STATE SERVICE
443/tcp    closed https
8080/tcp   closed http-proxy
Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds

```

Full Port Scan

nmap -p- 192.168.1.10

-p- Scan all 65535

```

(sakshi@kali)-[~]
└─$ nmap -p- 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:49 CDT
Nmap scan report for 192.168.137.129
Host is up (0.0000040s latency).
All 65535 scanned ports on 192.168.137.129 are in ignored states.
Not shown: 65535 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 0.97 seconds

```

Capture:

- Open ports
- Port states

3. Service Version Detection

nmap -sV 192.168.1.10

-sV Detect service versions

```

(sakshi@kali)-[~]
└─$ nmap -sV 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:50 CDT
Nmap scan report for 192.168.137.129
Host is up (0.0000060s latency).
All 1000 scanned ports on 192.168.137.129 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.48 seconds

```

nmap -sV -p 8080 192.168.137.129

```

(sakshi@kali)-[~]
$ nmap -sV -p 8080 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 10:48 CDT
Nmap scan report for 192.168.137.129
Host is up (0.00022s latency).

PORT      STATE SERVICE VERSION
8080/tcp  open  http    SimpleHTTPServer 0.6 (Python 3.13.3)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.13 seconds

(sakshi@kali)-[~]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.137.129 - - [18/May/2026 10:48:22] "GET / HTTP/1.0" 200 -
192.168.137.129 - - [18/May/2026 10:48:23] code 501, message Unsupported method ('POST')
192.168.137.129 - - [18/May/2026 10:48:23] "POST /sdk HTTP/1.1" 501 -
192.168.137.129 - - [18/May/2026 10:48:23] "GET / HTTP/1.0" 200 -
192.168.137.129 - - [18/May/2026 10:48:23] code 404, message File not found
192.168.137.129 - - [18/May/2026 10:48:23] "GET /nmaplowercheck1779119303 HTTP/1.1" 404 -
192.168.137.129 - - [18/May/2026 10:48:23] code 404, message File not found
192.168.137.129 - - [18/May/2026 10:48:23] "GET /HNAP1 HTTP/1.1" 404 -
192.168.137.129 - - [18/May/2026 10:48:23] code 404, message File not found
192.168.137.129 - - [18/May/2026 10:48:23] "GET /evox/about HTTP/1.1" 404 -

```

nmap -sV -p 8080,443 192.168.137.129

```

(sakshi@kali)-[~]
$ nmap -sV -p 8080,443 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:50 CDT
Nmap scan report for 192.168.137.129
Host is up (0.00012s latency).

PORT      STATE SERVICE
443/tcp   closed https
8080/tcp  closed http-proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.41 seconds

```

Example Output

443/tcp closed https
8080/tcp closed http-proxy

4. OS Detection

nmap -O 192.168.1.10

-O OS detection

```
(sakshi@kali)~$ nmap -O 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:50 CDT
Nmap scan report for 192.168.137.129
Host is up (0.000095s latency).
All 1000 scanned ports on 192.168.137.129 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.06 seconds
```

nmap -O -p 80,21 192.168.137.129

```
(sakshi@kali)~$ nmap -O -p 80,21 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:54 CDT
Nmap scan report for 192.168.137.129
Host is up (0.000091s latency).

PORT      STATE SERVICE
21/tcp    closed ftp
80/tcp    closed http
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.92 seconds
```

Capture:

- OS details

5. Aggressive Scan

nmap -A 192.168.1.10

```
(sakshi@kali)~$ nmap -A 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:55 CDT
Nmap scan report for 192.168.137.129
Host is up (0.000070s latency).
All 1000 scanned ports on 192.168.137.129 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.20 seconds
```


nmap -A -p 22,23 192.168.137.129

```
(sakshi@kali)-[~]
$ nmap -A -p 22,23 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:54 CDT
Nmap scan report for 192.168.137.129
Host is up (0.000088s latency).

PORT      STATE SERVICE VERSION
22/tcp    closed ssh
23/tcp    closed telnet
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.19 seconds
```

Includes:

- OS detection
- Version detection
- Script scanning
- Traceroute

6. Vulnerability Scan

nmap --script vuln 192.168.1.10

--script : vuln Run vulnerability scripts

```
(sakshi@kali)-[~]
$ nmap --script vuln 192.168.137.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 09:58 CDT
Nmap scan report for 192.168.137.129
Host is up (0.000016s latency).
All 1000 scanned ports on 192.168.137.129 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 10.89 seconds
```

Capture:

- Vulnerabilities found

Findings Section

1. Closed Ports:

8080,21,22,23, 80, 443

2. Services:

SSH, HTTP, HTTPS, http-proxy, ftp, telnet

3. OS:

Kali Linux

4. Possible Vulnerabilities:

SimpleHTTPServer 0.6 (Python 3.13.3) version detected

Conclusion

The task successfully demonstrated footprinting and reconnaissance techniques using multiple tools. Nmap scanning identified open ports, running services, and operating system details. Vulnerability scripts helped identify potential security weaknesses.

Task 2 - Vulnerability Assessment & Web Application Testing Report

Objectives

To perform vulnerability assessment and identify common web application vulnerabilities using security testing tools.

You will:

1. Perform Vulnerability Assessment
2. Scan Web Applications
3. Detect:
 - SQL Injection
 - XSS
 - Weak Headers
 - Weak Authentication
4. Document:
 - Risk Level
 - Proof of Concept
 - Mitigation
5. Create Final Report
6. Upload to GitHub

Tools Used

Tool	Purpose
OpenVAS	Vulnerability scanning
Nikto	Web server testing
SQLMap	SQL Injection testing
Hydra	Authentication testing
Curl	Header analysis

Step 1 — Update Kali Linux

sudo apt update && sudo apt upgrade -y

```
(sakshi@kali)-[~]
└─$ sudo apt update && sudo apt upgrade -y
[sudo] password for sakshi:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.9 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [116 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [258 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [910 kB]
Fetched 75.3 MB in 4min 35s (274 kB/s)
2185 packages can be upgraded. Run 'apt list --upgradable' to see them.
The following packages were automatically installed and are no longer required:
amass-common libgirepository-1.0-1 libsphinxbase3t64 python3-kismetcapturertladsb
curlftpfs libgpgme11t64 libsqlcipher1 python3-kismetcapturertlamr
firmware-ti-connectivity libgpgmepp6t64 libswscale8 python3-multipart
gir1.2-girepository-2.0 libhdf4-0-alt libteamctl0 python3-packaging-whl
libarmadillo14 libinstpatch-1.0-2 libtheora0 python3-pluginbase
libaudio2 libjs-jquery-ui libtsk19t64 python3-protobuf
libavc1394-0 libjs-underscore libudfread0 python3-pyinstaller-hooks-contrib
libavfilter10 libmongoc-1.0-0t64 libunibreak6 python3-pysmi
libavformat61 libmupdf25.1 libvdpau-va-gl1 python3-pysnmp4
libblosc2-4 libnet1 libwireshark18 python3-terminaltables
libbluray2 libogdi4.1 libwiretap15 python3-wheel-whl
libbson-1.0-0t64 libplacebo349 libwsutil16 python3-xlrd
libconfig-inifiles-perl libpocketsphinx3 mesa-vdpau-drivers python3-xlutils
libcrypt-dev libportmidi0 openjdk-21-jre python3-xlwt
libdisplay-info2 libpostproc58 openjdk-21-jre-headless python3-yaswfp
libdl12 libqt5ct-common1.8 pocketsphinx-en-us python3-zombie-imp
libfuse2t64 libradare2-5.0.0t64 python3-bluepy ruby-unf-ext
libgav1-1 librubberband2 python3-click-plugins samba-ad-dc
```

Step 2 — Install Required Tools

Install Nikto

`sudo apt install nikto -y`

Install SQLMap

`sudo apt install sqlmap -y`

Install OpenVAS / Greenbone

`sudo apt install gvm -y`

Setup OpenVAS

`sudo gvm-setup`

Start OpenVAS Services

`sudo gvm-start`

PART 1 — Vulnerability Assessment using OpenVAS

OpenVAS / Greenbone

Features:

- Vulnerability scanning
- CVE detection
- Weak configuration detection
- Risk scoring

Step 1 — Install gvm

Sudo apt install gvm -y

```
(sakshi@kali)-[~]
└─$ sudo apt install gvm -y
[sudo] password for sakshi:
The following package was automatically installed and is no longer required:
  libjs-underscore
Use 'sudo apt autoremove' to remove it.

Upgrading:
  gvm                      libgcrypt20          libpgpg-error0      libjs-sphinxdoc     libpq5          libxml2-utils      postgresql          postgresql-common
  gvm-common              libpgpg-error-1.0n  libgvm22t64        liblzma5            libxml2-dev     ospd-openvas       postgresql-client-common  xz-utils

Installing:
  gvm

Installing dependencies:
  greenbone-security-assistant  libpgpgme45  liblzma-dev          libxml2-16          postgresql-18-pg-gvm
  gsad                        libicu76     libmicrohttpd12t64  postgresql-18       postgresql-client-18
  gvm-tools                  libllvm21    libnet9              postgresql-18-jit   python3-terminaltables3

Suggested packages:
  liblzma-doc  postgresql-doc-18  python3-terminaltables3-doc

Summary:
  Upgrading: 16, Installing: 16, Removing: 0, Not Upgrading: 2173
  Download size: 23.2 MB / 66.2 MB
  Space needed: 271 MB / 59.1 GB available

Get:1 http://kali.download/kali kali-rolling/non-free amd64 greenbone-security-assistant all 26.17.0-0kali1 [2,176 kB]
Get:6 http://http.kali.org/kali kali-rolling/main amd64 postgresql-client-18 amd64 18.3-1+b1 [2,108 kB]
Get:12 http://mirror.kku.ac.th/kali kali-rolling/main amd64 gvm-common all 26.24.0-1 [122 kB]
Get:12 http://mirror.freedif.org/kali kali-rolling/main amd64 python3-terminaltables3 all 4.0.0-8 [15.0 kB]
Get:4 http://http.kali.org/kali kali-rolling/main amd64 libpq5 amd64 18.3-1+b1 [259 kB]
Get:3 http://mirror.sg.gs/kali kali-rolling/main amd64 ospd-openvas all 22.10.0-1 [90.9 kB]
Get:5 http://kali.download/kali kali-rolling/main amd64 postgresql-common all 290 [105 kB]
Get:7 http://http.kali.org/kali kali-rolling/main amd64 postgresql-18 amd64 18.3-1+b1 [7,259 kB]
Get:11 http://mirrors.ustc.edu.cn/kali kali-rolling/main amd64 gvm all 25.04.3 [12.1 kB]
Get:8 http://kali.download/kali kali-rolling/main amd64 postgresql-18-pg-gvm amd64 22.6.15-1 [20.2 kB]
Get:9 http://kali.download/kali kali-rolling/main amd64 libmicrohttpd12t64 amd64 1.0.5-1 [155 kB]
Get:10 http://kali.download/kali kali-rolling/main amd64 gsad amd64 24.16.0-1 [141 kB]
Get:13 http://kali.download/kali kali-rolling/main amd64 gvm-tools all 25.4.6-1 [153 kB]
Get:14 http://http.kali.org/kali kali-rolling/main amd64 libxml2-dev amd64 2.15.2+dfsg-0.1 [745 kB]
Get:15 http://http.kali.org/kali kali-rolling/main amd64 postgresql all 18+290 [10.0 kB]
Get:16 http://http.kali.org/kali kali-rolling/main amd64 postgresql-18-jit amd64 18.3-1+b1 [9,860 kB]
Fetched 23.2 MB in 15s (1,576 kB/s)
Extracting templates from packages: 100%
```

Step 2 — Setup

Sudo gvm-setup

```
(sakshi@kali)-[~]
└─$ sudo gvm-setup
This script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali

[>] Starting PostgreSQL service
[>] Creating GVM's certificate files
[>] Creating PostgreSQL database
[*] Creating database user
[*] Creating database
[*] Creating permissions
CREATE ROLE
[*] Applying permissions
GRANT ROLE
[*] Creating extension uuid-ossip
CREATE EXTENSION
[*] Creating extension pgcrypto
CREATE EXTENSION
[*] Creating extension pg-gvm
CREATE EXTENSION
[>] Migrating database
[>] Checking for GVM admin user
[*] Creating user admin for gvm
[*] Please note the generated admin password
[*] User created with password '38d0aad0-5be0-4b61-a3b9-604101e16af6'.
[*] Configure Feed Import Owner
[*] Define Feed Import Owner
[*] Update GVM feeds
Running as root. Switching to user 'gvm' and group 'gvm'.
Trying to acquire lock on /var/lib/openvas/feed-update.lock
Acquired lock on /var/lib/openvas/feed-update.lock
[>] Downloading Notus files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/notus/ to /var/lib/notus
```

Step 3 — Start OpenVAS Services

sudo gvm-start

```
(sakshi@kali)-[~]
└─$ sudo gvm-start
[>] Please wait for the GVM services to start.
[>] You might need to refresh your browser once it opens.
[>] Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

• gsad.service - Greenbone Security Assistant daemon (gsad)
  Loaded: loaded (/usr/lib/systemd/system/gsad.service; disabled; preset: disabled)
  Active: active (running) since Tue 2026-05-19 02:03:02 CDT; 152ms ago
  Invocation: 7b69417adea94195a9e4dcd9f9cfcde
  Docs: man:gsad(8)
        https://www.greenbone.net
  Main PID: 85842 (gsad)
  Tasks: 1 (limit: 4501)
  Memory: 1.5M (peak: 2.1M)
  CPU: 44ms
  CGroup: /system.slice/gsad.service
          └─85842 /usr/sbin/gsad --foreground --listen 127.0.0.1 --port 9392

May 19 02:03:02 kali systemd[1]: Starting gsad.service - Greenbone Security Assistant daemon (gsad) ...
May 19 02:03:02 kali systemd[1]: Started gsad.service - Greenbone Security Assistant daemon (gsad).
May 19 02:03:02 kali gsad[85842]: gsad main: INFO:2026-05-19 07h03.02 utc:85842: Starting GSAD version 24.16.0-git
May 19 02:03:03 kali gsad[85855]: gsad main: INFO:2026-05-19 07h03.02 utc:85855: Starting HTTP server on 127.0.0.1 and port 9392
May 19 02:03:03 kali gsad[85855]: gsad main: INFO:2026-05-19 07h03.02 utc:85855: gsad started successfully

• gvmd.service - Greenbone Vulnerability Manager daemon (gvmd)
  Loaded: loaded (/usr/lib/systemd/system/gvmd.service; disabled; preset: disabled)
  Active: active (running) since Tue 2026-05-19 02:02:57 CDT; 5s ago
  Invocation: 9024ab8dd97441fbafab0b31d42f453d
  Docs: man:gvmd(8)
  Process: 85748 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm (code=exited, status=0/SUCCESS)
  Main PID: 85755 (gvmd)
  Tasks: 3 (limit: 4501)
  Memory: 56.2M (peak: 56.2M)
  CPU: 4.894s
  CGroup: /system.slice/gvmd.service
          └─85755 "gvmd: waiting" --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm
             └─85784 "gvmd: synchron" --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm
                └─85794 "gvmd: syncing" --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=_gvm

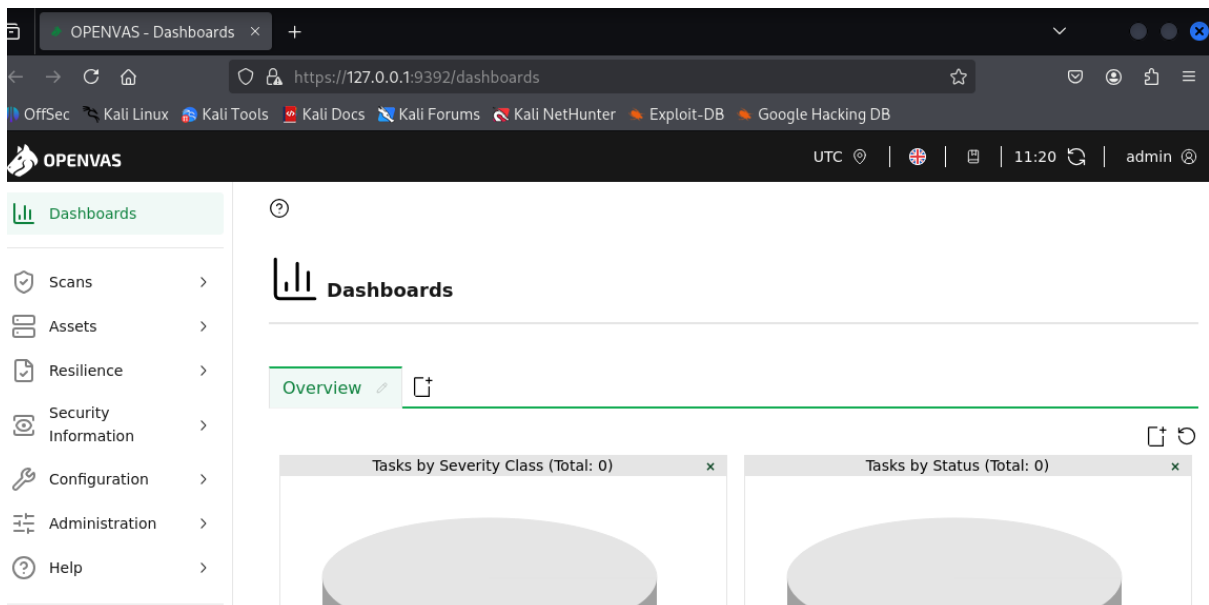
May 19 02:02:55 kali systemd[1]: Starting gvmd.service - Greenbone Vulnerability Manager daemon (gvmd) ...
May 19 02:02:55 kali systemd[1]: gvmd.service: Can't open PID file '/run/gvmd/gvmd.pid' (yet?) after start: No such file or directory
```

Step 4 — Open Web Interface

After starting GVM (Greenbone Vulnerability Management):

<https://127.0.0.1:9392>

Login using generated credentials.



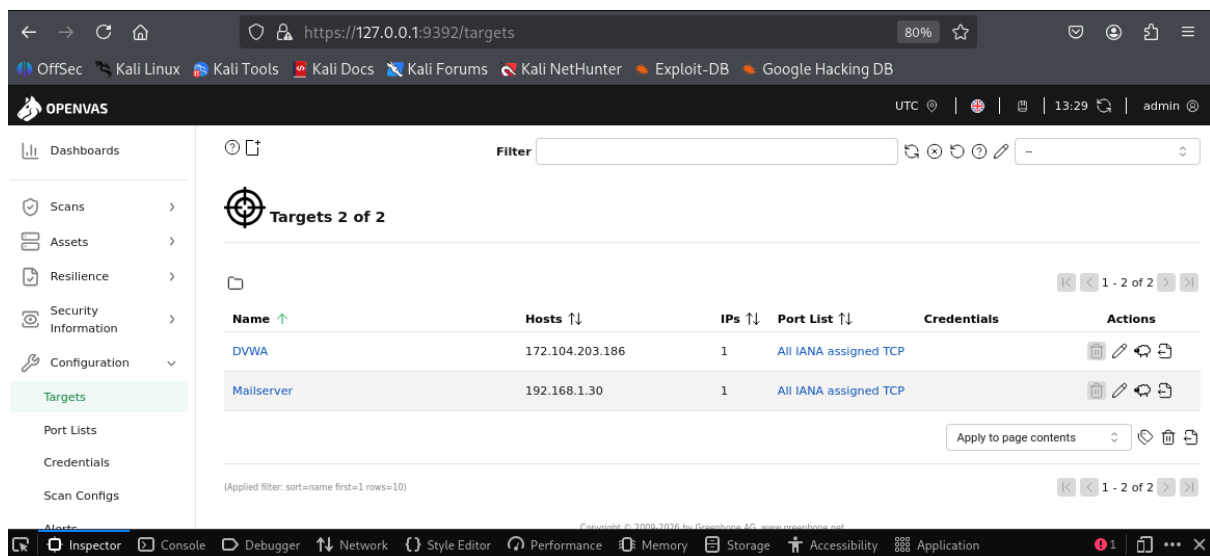
Step 5 — Create Target

Navigate:

Configuration → Targets → New Target → Add Targets Details → save Targets

Add:

- Target Name
- Target IP



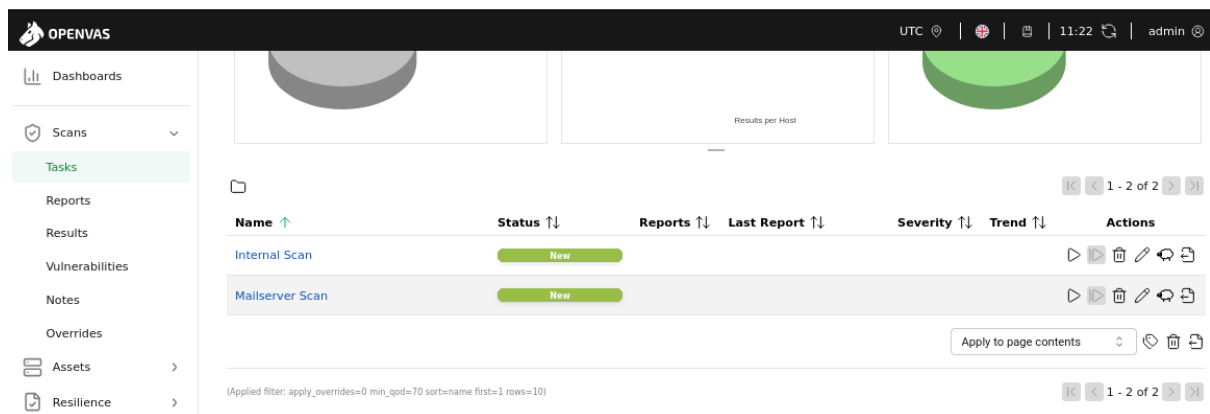
Step 6 — Create Scan Task

Navigate:

Scans → Tasks → New Task

Select:

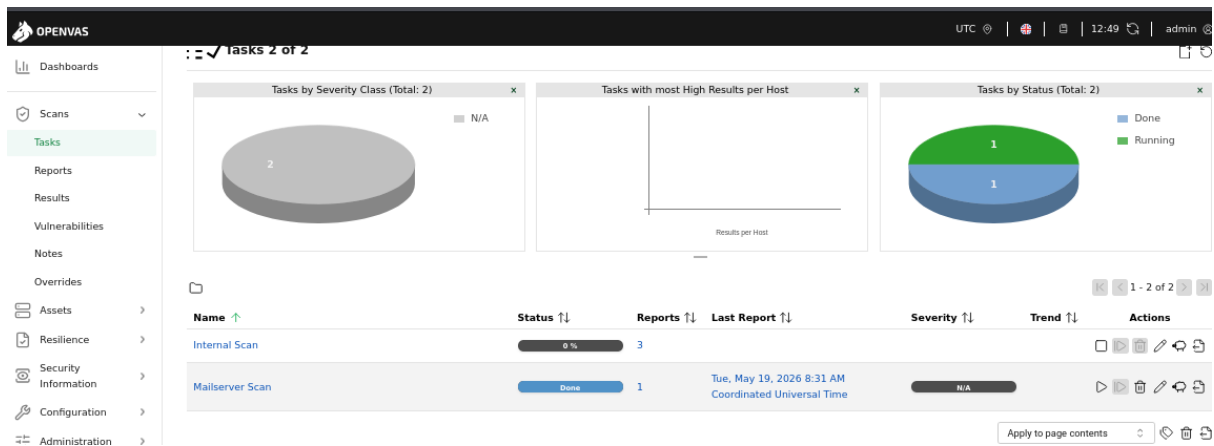
- Scan Config: Full and Fast
- Target: Your target



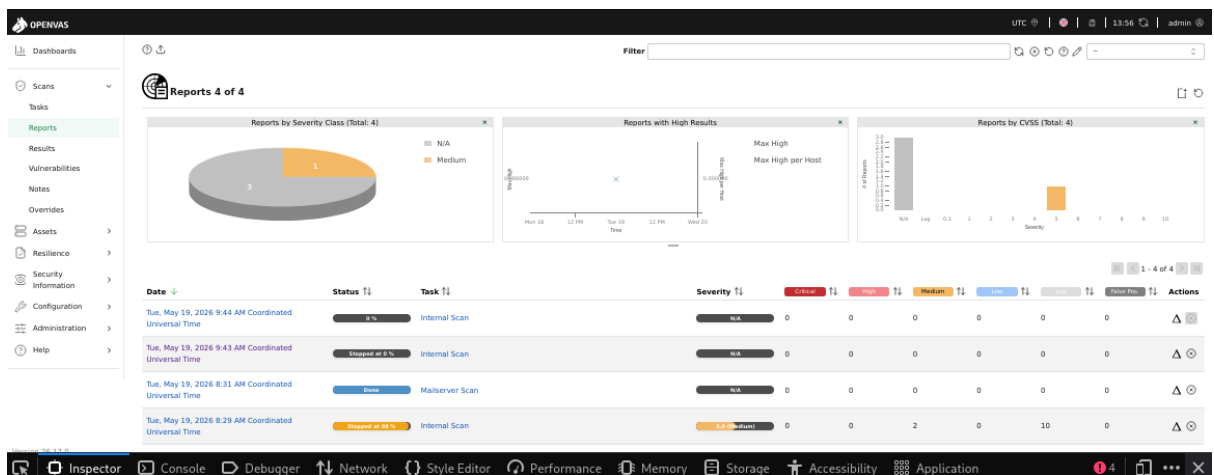
Step 7 — Start Scan

Click:

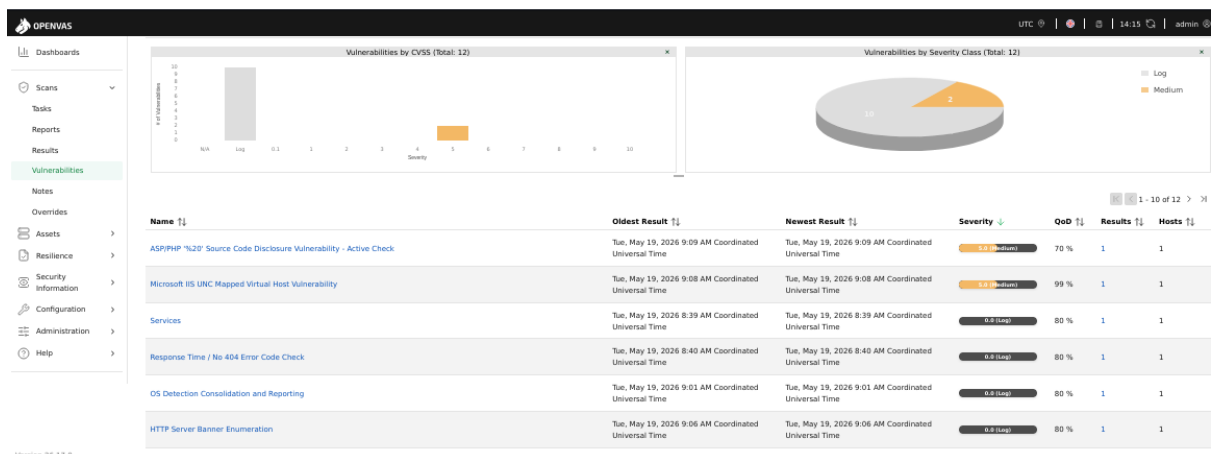
- Start Scan



Report:



Vulnerability report:



Capture:

- Dashboard
- Target creation
- Scan progress
- Vulnerability report

- Severity ratings

Findings Example

Vulnerability	Severity
Outdated Apache	Medium
Weak SSL Cipher	High
Open SMB Service	Medium

PART 2 — Web Application Testing with Nikto

Nikto

Nikto scans:

- Dangerous files
- Misconfigurations
- Default pages
- Weak headers
- Old software

Official:

[Nikto GitHub](#)

1. Basic Nikto Scan

nikto -h http://192.168.137.133

Purpose: Identify web server vulnerabilities and insecure configurations.

```

(sakshi@kali)-[~]
└─$ nikto -h http://192.168.137.133
- Nikto v2.5.0

+ Target IP: 192.168.137.133
+ Target Hostname: 192.168.137.133
+ Target Port: 80
+ Start Time: 2026-05-19 05:59:37 (GMT-5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/5275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracking

+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /~PHE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /~PHE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /~PHE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /~PHE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 11:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-05-19 06:00:44 (GMT-5) (67 seconds)

+ 1 host(s) tested

```

2. HTTPS Scan

nikto -h https://192.168.1.10

3. Save Report

nikto -h http://192.168.1.10 -o nikto-report.html -Format html

Command	Purpose
-h	Target host
-o	Output file
-Format htm	HTML report

```
(sakshi@kali)~$ nikto -h http://192.168.137.133 -o nikto-repot.html -Format html
- Nikto v2.5.0

+ Target IP: 192.168.137.133
+ Target Hostname: 192.168.137.133
+ Target Port: 80
+ Start Time: 2026-05-19 06:27:43 (GMT-5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15 https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /~PHPBB5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OS VDB-12184
+ /~PHP9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OS VDB-12184
+ /~PHP9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OS VDB-12184
+ /~PHP9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OS VDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/changelog: Server may leak inodes via ETags, header found with file /phpMyAdmin/Changelog, inode: 92462, size: 40540, mtime: Tue Dec 9 11:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/Changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8810 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-05-19 06:28:41 (GMT-5) (58 seconds)

+ 1 host(s) tested
```

Capture:

- Scan results
- Vulnerabilities
- Headers
- Server information

Example Findings

Missing X-Frame-Options Header
Outdated Apache Version
Directory Listing Enabled

PART 3 — SQL Injection Testing

SQLMap

[SQLMap Official Website](#)

SQLMap automates:

- SQL Injection detection
- Database fingerprinting
- Database extraction

Test URL Example

"<http://192.168.137.133/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit>"

Use only legal practice labs.

1. Basic SQLMap Scan

sudo sqlmap -u

"http://192.168.137.133/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --batch

```
(sakshi@kali)-[~]$ sudo sqlmap -u "http://192.168.137.133/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --batch
[+] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal
re not responsible for any misuse or damage caused by this program
[*] starting @ 08:44:54 /2026-05-19/
[08:44:54] [INFO] testing connection to the target URL
got a 302 redirect to 'http://192.168.137.133/dvwa/login.php'. Do you want to follow? [Y/n] Y
you have not declared cookie(s), while server wants to set its own ('PHPSESSID=f4b87636470...5eb5b272ab;security=high;security=high'). Do you want to use those [Y/n] Y
[08:44:55] [INFO] testing if the target URL content is stable
[08:44:55] [WARNING] GET parameter 'id' does not appear to be dynamic
[08:44:55] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be injectable
[08:44:55] [INFO] testing for SQL injection on GET parameter 'id'
[08:44:55] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[08:44:56] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[08:44:56] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[08:44:56] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[08:44:57] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[08:44:57] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[08:44:58] [INFO] testing 'Generic inline queries'
[08:44:58] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[08:44:58] [WARNING] time-based comparison requires larger statistical model, please wait. (done)
[08:44:58] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[08:44:58] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[08:44:59] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[08:44:59] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[08:45:00] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[08:45:00] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[08:45:00] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[08:45:01] [WARNING] GET parameter 'id' does not seem to be injectable
[08:45:01] [WARNING] GET parameter 'Submit' does not appear to be dynamic
[08:45:01] [WARNING] heuristic (basic) test shows that GET parameter 'Submit' might not be injectable
[08:45:01] [INFO] testing for SQL injection on GET parameter 'Submit'
[08:45:01] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[08:45:01] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[08:45:01] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[08:45:02] [INFO] testing 'PostgreSQL AND error-based - WHERE, HAVING clause'
[08:45:02] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[08:45:02] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[08:45:02] [INFO] testing 'Generic inline queries'
[08:45:03] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[08:45:03] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
```

2. Database Enumeration

sudo sqlmap -u

**"http://192.168.137.133/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" **

**--cookie="security=low; PHPSESSID=79df77de78a59c6460808f8f475d4247334" **

--dbs

Part	Meaning
-u	Target URL
--batch	Auto answer prompts
--dbs	List databases

```
(sakshi@kali)-[~]
└─$ sudo sqlmap -u "http://192.168.137.133/dvwa/vulnerabilities/sqli/?id=16Submit=Submit" \
--cookie="security=low; PHPSESSID=79df77de78a59c6460808f8f475d4247334" \
--dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 08:36:44 /2026-05-19/

[08:36:44] [INFO] testing connection to the target URL
got a 302 redirect to 'http://192.168.137.133/dvwa/login.php'. Do you want to follow? [Y/n] y
[08:36:48] [INFO] testing if the target URL content is stable
[08:36:49] [WARNING] GET parameter 'id' does not appear to be dynamic
[08:36:50] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be injectable
[08:36:50] [INFO] testing for SQL injection on GET parameter 'id'
[08:36:50] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[08:36:50] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[08:36:51] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[08:36:51] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[08:36:52] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[08:36:52] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[08:36:53] [INFO] testing 'Generic inline queries'
[08:36:53] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[08:36:53] [WARNING] time-based comparison requires larger statistical model, please wait. (done)
[08:36:53] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[08:36:53] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[08:36:54] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[08:36:54] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[08:36:55] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[08:36:56] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] y
[08:36:56] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[08:36:59] [WARNING] GET parameter 'id' does not seem to be injectable
[08:36:59] [WARNING] GET parameter 'Submit' does not appear to be dynamic
[08:36:59] [WARNING] heuristic (basic) test shows that GET parameter 'Submit' might not be injectable
[08:36:59] [INFO] testing for SQL injection on GET parameter 'Submit'
[08:36:59] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[08:37:00] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[08:37:00] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[08:37:00] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[08:37:01] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[08:37:01] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[08:37:02] [INFO] testing 'Generic inline queries'
[08:37:02] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[08:37:02] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[08:37:03] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
```

Capture:

- Injection detection
- Database names
- Payload results

Example Findings

Parameter 'submit' vulnerable to SQL Injection

Backend DBMS: MySQL

PART 4 — Cross-Site Scripting (XSS)

What is XSS?

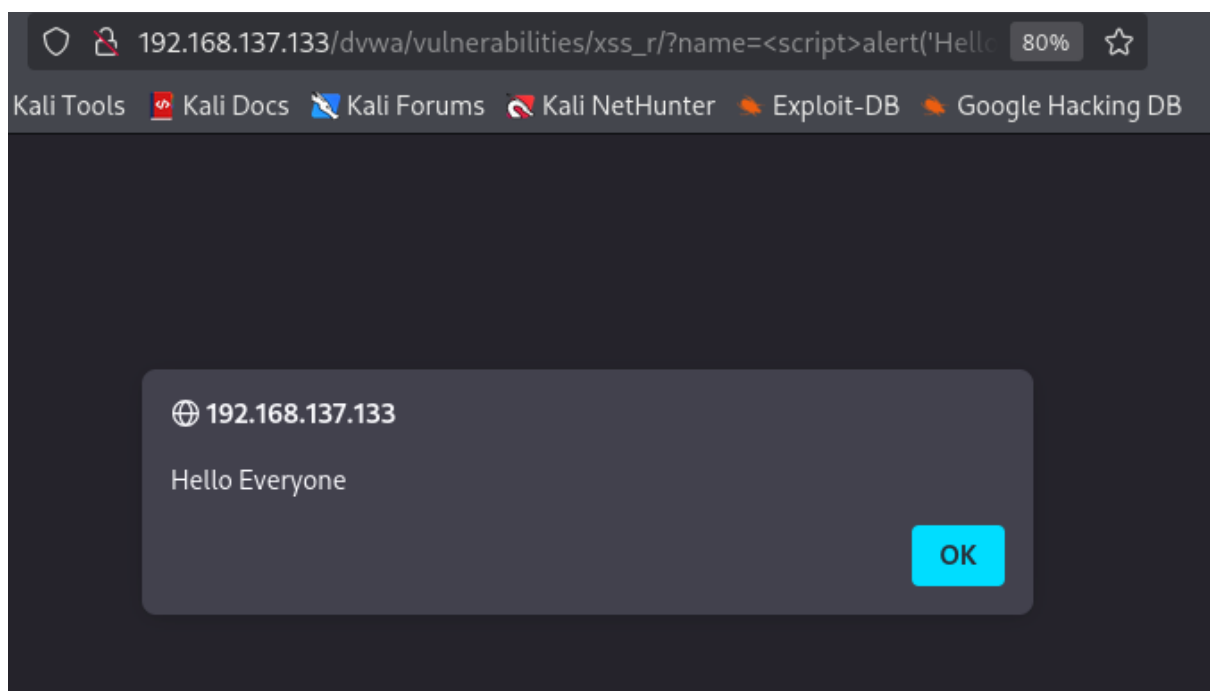
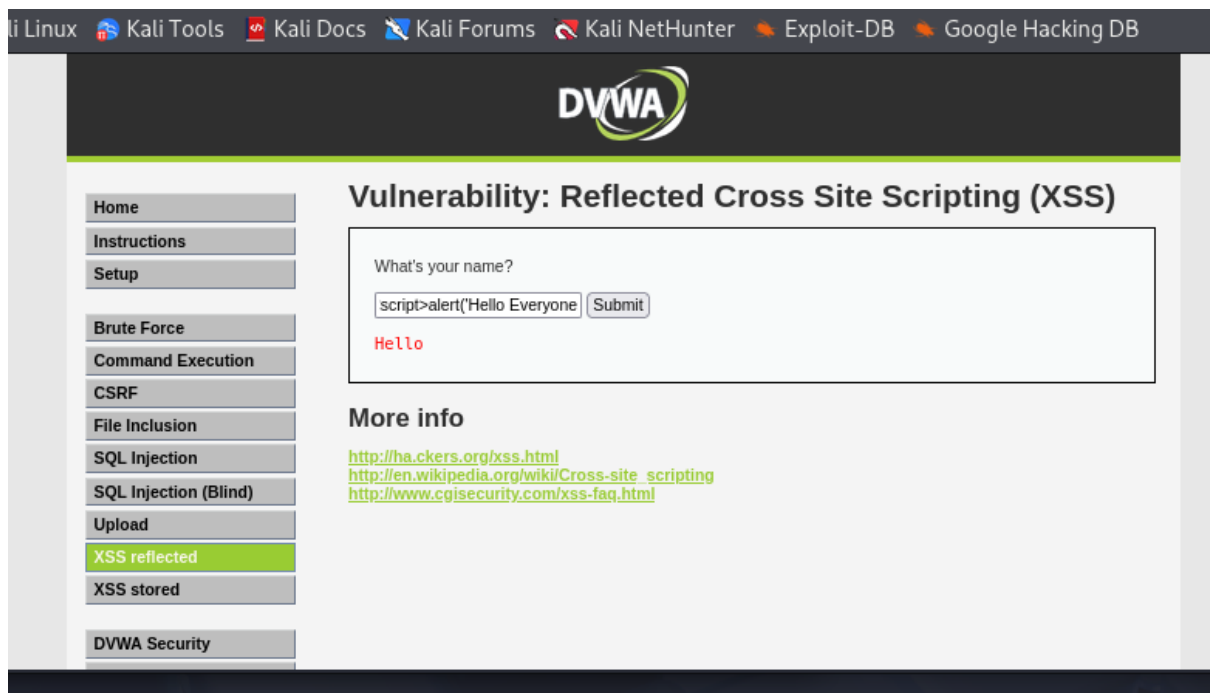
XSS allows attackers to inject malicious JavaScript into webpages.

Types:

- Reflected XSS
- Stored XSS
- DOM XSS

Basic XSS Test Payload

```
<script>alert('XSS')</script>
```

Result: Alert popup executed successfully.

Test Procedure

1. Find input field
2. Enter payload
3. Submit form
4. Observe popup alert

Capture:

- Input field
- Payload

- Alert popup

Risk Level

Severity	Impact
Medium	Session theft
High	Account compromise

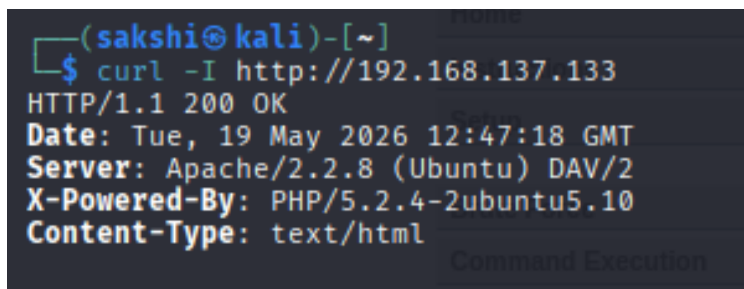
Mitigation

Use input validation and output encoding.
Implement Content Security Policy (CSP).

PART 5 — Insecure Headers Testing

Check Headers using CURL

curl -I <http://192.168.137.133>

A terminal window with a dark background. The prompt is (sakshi@kali)-[~]. The command executed is \$ curl -I http://192.168.137.133. The output is: HTTP/1.1 200 OK, Date: Tue, 19 May 2026 12:47:18 GMT, Server: Apache/2.2.8 (Ubuntu) DAV/2, X-Powered-By: PHP/5.2.4-2ubuntu5.10, Content-Type: text/html. The text "Command Execution" is visible in the bottom right corner of the terminal window.

```
(sakshi@kali)-[~]  
$ curl -I http://192.168.137.133  
HTTP/1.1 200 OK  
Date: Tue, 19 May 2026 12:47:18 GMT  
Server: Apache/2.2.8 (Ubuntu) DAV/2  
X-Powered-By: PHP/5.2.4-2ubuntu5.10  
Content-Type: text/html  
Command Execution
```

Important Security Headers

Header	Purpose
X-Frame-Options	Prevent clickjacking
Content-Security-Policy	Prevent XSS
Strict-Transport-Security	Force HTTPS

Weak Header Example

Missing X-Frame-Options Header

Mitigation Example

Header always set X-Frame-Options "DENY"

PART 6 — Weak Authentication Testing

Hydra Login Testing

Install Hydra

sudo apt install hydra -y

```
(sakshi@kali)~$ sudo apt install hydra -y
[sudo] password for sakshi:
The following packages were automatically installed and are no longer required:
base58                                postgresql-17                        python3-flask-mail                  python3-sh
binutils-mingw-w64-1686               postgresql-client-17                python3-flask-principal            python3-simple-rest-client
binutils-mingw-w64-x86-64             postgresql-client-18                python3-flask-sqlalchemy           python3-simplekv
dnsmasq                               postgresql-client-common             python3-flaskext.wtf               python3-slugify
dsniff                               postgresql-common                   python3-flatbuffers                python3-smmmap
ettercap-common                       python-odf-doc                       python3-gevent                     python3-snappy
ettercap-graphical                    python-odf-tools                     python3-gevent-websocket           python3-spinners
figlet                                python3-tables-data                  python3-git                         python3-sqlalchemy-schemadisplay
finger                                python3-alembic                     python3-gitdb                       python3-sqlparse
gcc-mingw-w64-base                     python3-amqp                         python3-html2text                   python3-standard-imghdr
gcc-mingw-w64-1686-win32              python3-apispec                      python3-hupper                      python3-status
gcc-mingw-w64-1686-win32-runtime       python3-apispec-webframeworks        python3-kombu                       python3-syslog-rfc5424-formatter
gcc-mingw-w64-x86-64-win32            python3-autobahn                     python3-llvmlite                    python3-tables
gcc-mingw-w64-x86-64-win32-runtime     python3-base58                      python3-log-symbols                 python3-tables-lib
girl1.2-vte-2.91                       python3-billiard                     python3-marshal                     python3-tld
imagemagick                           python3-bleach                       python3-marshmallow-sqlalchemy      python3-translationstring
imagemagick-7.q16                      python3-bottle                       python3-memcache                    python3-trie
libaio1t64                             python3-bottleneck                   python3-mnemonic                    python3-txaio
libapache2-mod-php                     python3-cbor                         python3-nplusone                     python3-tzlocal
libblosc2-4                             python3-celery                       python3-numba                       python3-u-msgpack
libbson-1.0-0t64                       python3-cli-helpers                  python3-numexpr                      python3-ubjson
libgpgme45                              python3-click-didyoumean              python3-odf                          python3-unidecode
libgvm22t64                            python3-click-repl                    python3-ordered-set                 python3-validators
libhiredis1.1.0                         python3-cmd2                         python3-pandas                       python3-validators
libical3t64                            python3-configobj                     python3-pandas-lib                  python3-venusian
libc6u8                                 python3-cpuinfo                      python3-pefile                       python3-vine
libllvm21                               python3-croniter                     python3-pgspecial                    python3-webargs
liblua5.1-2                             python3-cvss                         python3-plaster                      python3-wsaccel
liblua5.1-common                       python3-defusedxml                    python3-plaster-pastedeploy          python3-wtforms
libmongoc-1.0-0t64                     python3-django                       python3-png                          python3-yaswfp
libnet9                                 python3-ecdsa                         python3-psycogreen                   python3-zope.deprecation
libnids1.21t64                         python3-elastictransport              python3-psycopg                      python3-zope.event
libpaho-mqtt1.3                         python3-elasticsearch                 python3-psycopg-c                    rsh-redone-client
libradcli4                             python3-ephem                         python3-py-sneakers                  smtp-user-enum
sparta-scripts
```

hydra -l msfadmin -P /home/sakshi/wordlist.txt -vv -f ftp://192.168.137.133

```
(sakshi@kali)~$ hydra -l msfadmin -P /home/sakshi/wordlist.txt -vv -f ftp://192.168.137.133
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
ng, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-19 09:01:54
[DATA] max 5 tasks per 1 server, overall 5 tasks, 5 login tries (l:1/p:5), ~1 try per task
[DATA] attacking ftp://192.168.137.133:21/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "msfadmin@" - 1 of 5 [child 0] (0/0)
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "admin" - 2 of 5 [child 1] (0/0)
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "sdewr764" - 3 of 5 [child 2] (0/0)
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "ad@m!78" - 4 of 5 [child 3] (0/0)
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "msfadmin" - 5 of 5 [child 4] (0/0)
[21][ftp] host: 192.168.137.133 login: msfadmin password: msfadmin
[STATUS] attack finished for 192.168.137.133 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-19 09:01:55
```

Part	Meaning
-l	Username
-P	Password wordlist
http-post-form	Login form attack

Capture:

- Login page
- Hydra results
- Successful login (if found)

PART 7 — Risk Assessment Table

Vulnerability	Severity	Risk
SQL Injection	Critical	Database compromise
XSS	High	Session theft
Weak Headers	Medium	Browser attacks
Weak Password	High	Unauthorized access

Findings Section

1. SQL Injection vulnerability detected.
2. Missing security headers identified.
3. Weak admin credentials discovered.
4. Outdated Apache server detected.

Mitigation Section

Vulnerability	Mitigation
SQL Injection	Use prepared statements
XSS	Encode user input
Weak Headers	Configure secure headers
Weak Passwords	Enforce strong password policy

Conclusion

The assessment successfully identified multiple vulnerabilities including SQL Injection, XSS, weak headers, and insecure authentication mechanisms. Appropriate mitigation techniques were recommended to improve security posture.

Task 3 - Password Security, Sniffing & Session Analysis Report

Objectives

To analyze network traffic, perform password auditing, and study secure session management concepts.

You will:

1. Capture packets using Wireshark
2. Analyze:
 - HTTP traffic
 - DNS traffic
 - TCP traffic
 - ARP traffic
3. Perform password auditing
4. Understand session management
5. Learn session hijacking risks
6. Document findings
7. Upload project to GitHub

Tools Used

Tool	Purpose
Wireshark	Packet analysis
John the Ripper	Password auditing
Hydra	Login testing
Curl	Session/header inspection

Step 1 — Update Kali Linux

sudo apt update && sudo apt upgrade -y

```
(sakshi@kali)-[~]
└─$ sudo apt update && sudo apt upgrade -y
[sudo] password for sakshi:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.9 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [116 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [258 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [910 kB]
Fetched 75.3 MB in 4min 35s (274 kB/s)
2185 packages can be upgraded. Run 'apt list --upgradable' to see them.
The following packages were automatically installed and are no longer required:
amass-common libgirepository-1.0-1 libsphinxbase3t64 python3-kismetcapturertladsb
curlftps libpgme11t64 libsqlcipher1 python3-kismetcapturertlamr
firmware-ti-connectivity libpgmepp6t64 libswscale8 python3-multipart
gir1.2-girepository-2.0 libhdf4-0-alt libteamctl0 python3-packaging-whl
libarmadillo14 libinstpatch-1.0-2 libtheora0 python3-pluginbase
libaudio2 libjs-jquery-ui libtsk19t64 python3-protobuf
libavc1394-0 libjs-underscore libudfread0 python3-pyinstaller-hooks-contrib
libavfilter10 libmongoc-1.0-0t64 libunibreak6 python3-pysmi
libavformat61 libmupdf25.1 libvdpau-va-gl1 python3-pysnmp4
libblsc2-4 libnet1 libwireshark18 python3-terminaltables
libluray2 libogdi4.1 libwiretap15 python3-wheel-whl
libbson-1.0-0t64 libplacebo349 libwsutil16 python3-xlrd
libconfig-inifiles-perl libpocketsphinx3 mesa-vdpau-drivers python3-xlutils
libcrypt-dev libportmidi0 openjdk-21-jre python3-xlwt
libdisplay-info2 libpostproc58 openjdk-21-jre-headless python3-yaswfp
libdl2 libqt5ct-common1.8 pocketsphinx-en-us python3-zombie-imp
libfuse2t64 libradare2-5.0.0t64 python3-bluepy ruby-unf-ext
libgav1-1 librubberband2 python3-click-plugins samba-ad-dc
```

Step 2 — Install Required Tools

1. Install Wireshark

`sudo apt install wireshark -y`

2. Install John the Ripper

`sudo apt install john -y`

3. Install Hydra

`sudo apt install hydra -y`

PART 1 — Packet Capturing using Wireshark

Wireshark

Wireshark captures and analyses network packets.

Features:

- Live traffic monitoring
- Protocol analysis
- Packet filtering
- Session inspection

Step 1 — Start Wireshark

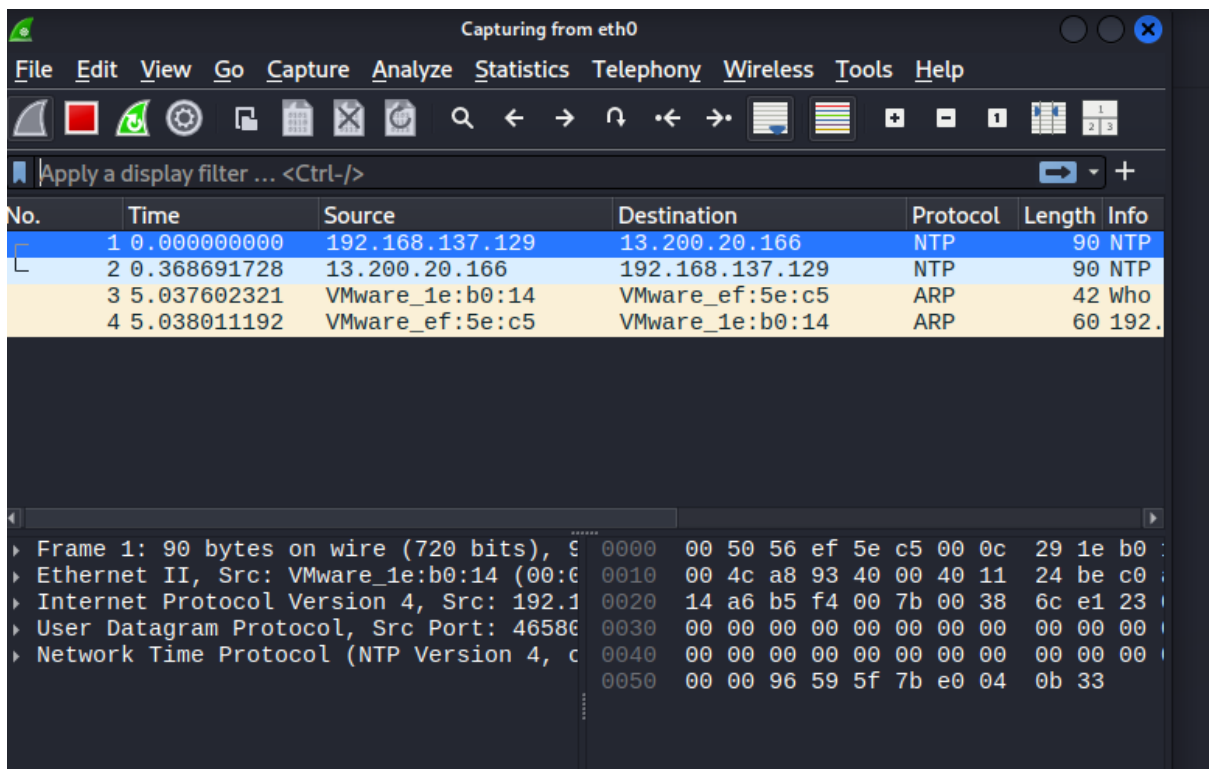
`sudo wireshark`

```
File Actions Edit View Help Capture Analyze Statistics Telephony Wireless Tools Help
(sakshi@kali)-[~]
└─$ sudo wireshark
[sudo] password for sakshi:
** (wireshark:2247) 12:55:02.565418 [Capture MESSAGE] -- Capture Start ...
** (wireshark:2247) 12:55:02.652008 [Capture MESSAGE] -- Capture started
** (wireshark:2247) 12:55:02.652203 [Capture MESSAGE] -- File: "/tmp/wireshark_eth01VJBP3.pcapng"
```

Step 2 — Select Network Interface

Choose:

- eth0
- wlan0



Click: Start Capturing Packets

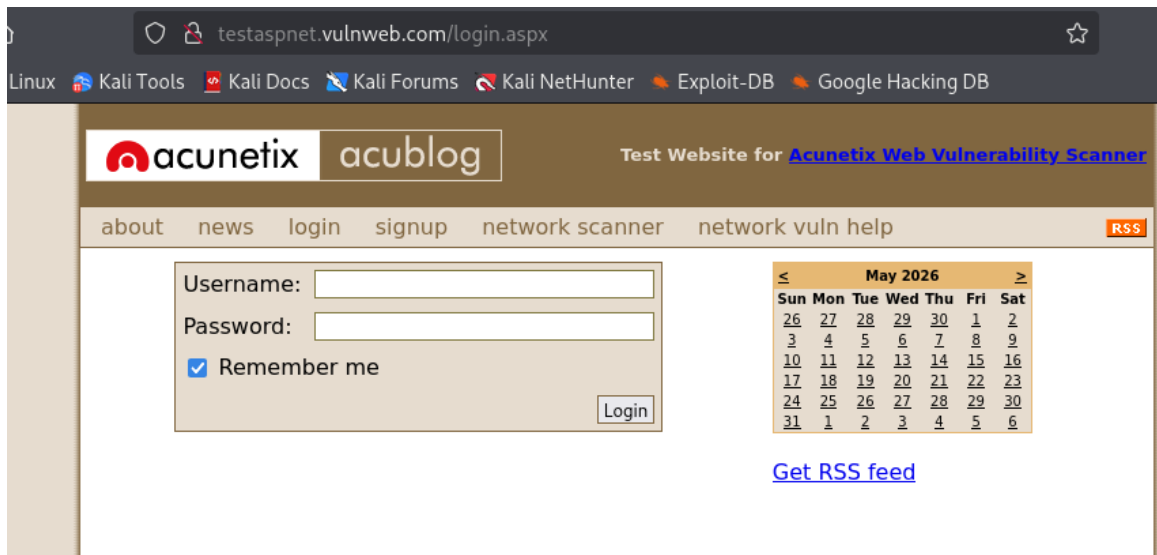
Step 3 — Generate Network Traffic

Open browser and visit:

- Any legal practice website
- Your local lab server

Python3 –m http.server 8080

```
(sakshi@kali)-[~]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
127.0.0.1 - - [19/May/2026 13:09:41] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [19/May/2026 13:09:42] code 404, message File not found
127.0.0.1 - - [19/May/2026 13:09:42] "GET /favicon.ico HTTP/1.1" 404 -
127.0.0.1 - - [19/May/2026 13:13:41] "GET / HTTP/1.1" 200 -
```



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.137.129	13.200.20.166	NTP	90	NTP Version 4, client
2	0.368691728	13.200.20.166	192.168.137.129	NTP	90	NTP Version 4, server
3	5.037602321	VMware_1e:b0:14	VMware_ef:5e:c5	ARP	42	Who has 192.168.137.2? Tell 192.168.137.129
4	5.038011192	VMware_ef:5e:c5	VMware_1e:b0:14	ARP	60	192.168.137.2 is at 00:50:56:ef:5e:c5
5	64.499363968	192.168.137.129	13.200.20.166	NTP	90	NTP Version 4, client
6	64.584403534	13.200.20.166	192.168.137.129	NTP	90	NTP Version 4, server
7	69.549592557	VMware_1e:b0:14	VMware_ef:5e:c5	ARP	42	Who has 192.168.137.2? Tell 192.168.137.129
8	69.551312802	VMware_ef:5e:c5	VMware_1e:b0:14	ARP	60	192.168.137.2 is at 00:50:56:ef:5e:c5
9	124.978715540	fe80::20c:29ff:fe1e... ff02::2		ICMPv6	62	Router Solicitation
10	171.583200337	169.254.41.248	169.254.255.255	BROWSER	243	Host Announcement DESKTOP-SCPML7Q, Workstation,

Step 4 — Stop Capture

Click: **Stop Capture**

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.137.129	13.200.20.166	NTP	90	NTP Version 4, client
2	0.368691728	13.200.20.166	192.168.137.129	NTP	90	NTP Version 4, server
3	5.037602321	VMware_1e:b0:14	VMware_ef:5e:c5	ARP	42	Who has 192.168.137.2? Tell 192.168.137.129
4	5.038011192	VMware_ef:5e:c5	VMware_1e:b0:14	ARP	60	192.168.137.2 is at 00:50:56:ef:5e:c5
5	64.499363968	192.168.137.129	13.200.20.166	NTP	90	NTP Version 4, client
6	64.584403534	13.200.20.166	192.168.137.129	NTP	90	NTP Version 4, server
7	69.549592557	VMware_1e:b0:14	VMware_ef:5e:c5	ARP	42	Who has 192.168.137.2? Tell 192.168.137.129
8	69.551312802	VMware_ef:5e:c5	VMware_1e:b0:14	ARP	60	192.168.137.2 is at 00:50:56:ef:5e:c5
9	124.978715540	fe80::20c:29ff:fe1e... ff02::2		ICMPv6	62	Router Solicitation
10	171.583200337	169.254.41.248	169.254.255.255	BROWSER	243	Host Announcement DESKTOP-SCPML7Q, Workstat

Frame 10: 243 bytes on wire (1944 bits), 243 bytes captured (.....) on interface 0

Ethernet II, Src: VMware_c0:00:08 (00:50:56:c0:00:08), Dst: B0:00:00:00:00:00

Internet Protocol Version 4, Src: 169.254.41.248, Dst: 169.254.255.255

User Datagram Protocol, Src Port: 138, Dst Port: 138

NetBIOS Datagram Service

Capture:

- Wireshark dashboard
 - Live packet capture
 - Filtered traffic
-

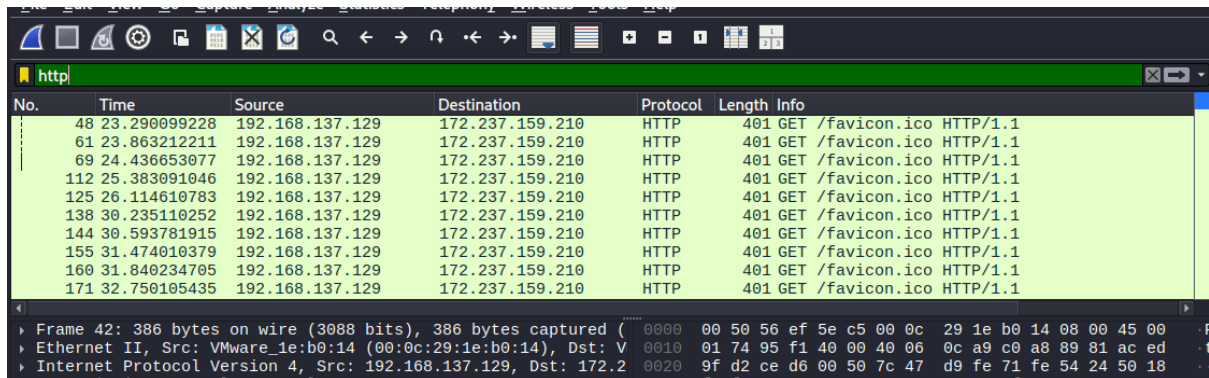
PART 2 — HTTP Traffic Analysis

Filter HTTP Packets

In filter bar: http

Check:

- GET requests
- POST requests
- URLs
- Cookies data
- Plaintext



No.	Time	Source	Destination	Protocol	Length	Info
48	23.290099228	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
61	23.863212211	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
69	24.436653077	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
112	25.383091046	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
125	26.114610783	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
138	30.235110252	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
144	30.593781915	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
155	31.474010379	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
160	31.840234705	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1
171	32.750105435	192.168.137.129	172.237.159.210	HTTP	401	GET /favicon.ico HTTP/1.1

Frame 42: 386 bytes on wire (3088 bits), 386 bytes captured (3088 bits) on interface 0
Ethernet II, Src: VMware_1e:b0:14 (00:0c:29:1e:b0:14), Dst: V 0010 01 74 95 f1 40 00 40 06 0c a9 c0 a8 89 81 ac ed
Internet Protocol Version 4, Src: 192.168.137.129, Dst: 172.2 0020 9f d2 ce d6 00 50 7c 47 d9 fe 71 fe 54 24 50 18

Capture:

- HTTP packets
- Request headers
- Response packets

Risk Explanation

HTTP traffic is unencrypted.

Risks:

- Credential theft
 - Session hijacking
 - Data interception
-

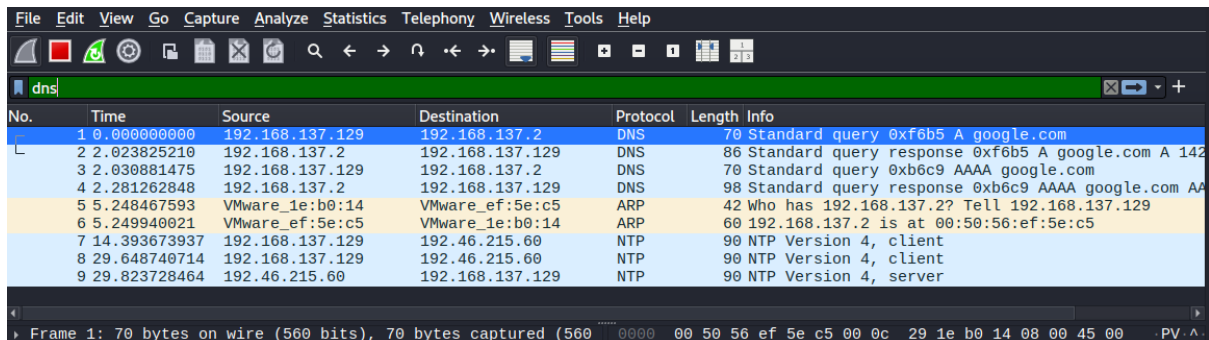
PART 3 — DNS Traffic Analysis

Apply DNS Filter

dns

Look for:

- Domain queries
- DNS responses
- IP mappings



A screenshot of the Wireshark network protocol analyzer showing a capture of DNS traffic. The packet list pane on the left shows several packets, with packet 1 selected. The packet details pane on the right shows the structure of the selected packet, which is a Standard query response from 192.168.137.2 to 192.168.137.129. The packet bytes pane at the bottom shows the raw data of the packet.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.137.129	192.168.137.2	DNS	70	Standard query 0xf6b5 A google.com
2	2.023825210	192.168.137.2	192.168.137.129	DNS	86	Standard query response 0xf6b5 A google.com A 142
3	2.030881475	192.168.137.129	192.168.137.2	DNS	70	Standard query 0xb6c9 AAAA google.com
4	2.281262848	192.168.137.2	192.168.137.129	DNS	98	Standard query response 0xb6c9 AAAA google.com AA
5	5.248467593	VMware_1e:b0:14	VMware_ef:5e:c5	ARP	42	Who has 192.168.137.2? Tell 192.168.137.129
6	5.249940021	VMware_ef:5e:c5	VMware_1e:b0:14	ARP	60	192.168.137.2 is at 00:50:56:ef:5e:c5
7	14.393673937	192.168.137.129	192.46.215.60	NTP	90	NTP Version 4, client
8	29.648740714	192.168.137.129	192.46.215.60	NTP	90	NTP Version 4, client
9	29.823728464	192.46.215.60	192.168.137.129	NTP	90	NTP Version 4, server

Capture:

- DNS requests
- DNS responses

Risk Explanation

DNS can reveal:

- Browsing activity
- Internal domains
- Infrastructure details

PART 4 — TCP Traffic Analysis

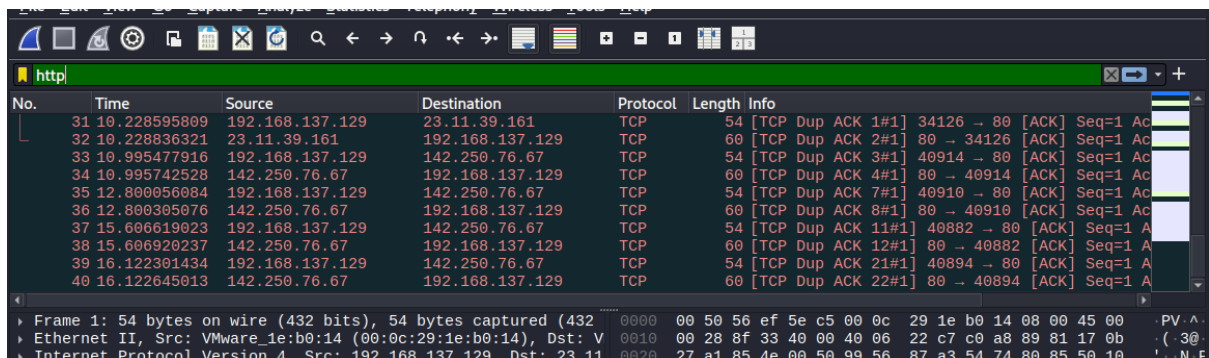
Apply TCP Filter

tcp

Analyze TCP Handshake

Observe:

1. SYN
2. SYN-ACK
3. ACK



A screenshot of the Wireshark network protocol analyzer showing a capture of TCP traffic. The packet list pane on the left shows several packets, with packet 31 selected. The packet details pane on the right shows the structure of the selected packet, which is a TCP Dup ACK 1#1 from 192.168.137.129 to 23.11.39.161. The packet bytes pane at the bottom shows the raw data of the packet.

No.	Time	Source	Destination	Protocol	Length	Info
31	10.228595809	192.168.137.129	23.11.39.161	TCP	54	[TCP Dup ACK 1#1] 34126 → 80 [ACK] Seq=1 Ac
32	10.228836321	23.11.39.161	192.168.137.129	TCP	60	[TCP Dup ACK 2#1] 80 → 34126 [ACK] Seq=1 Ac
33	10.995477916	192.168.137.129	142.250.76.67	TCP	54	[TCP Dup ACK 3#1] 40914 → 80 [ACK] Seq=1 Ac
34	10.995742528	142.250.76.67	192.168.137.129	TCP	60	[TCP Dup ACK 4#1] 80 → 40914 [ACK] Seq=1 Ac
35	12.800056084	192.168.137.129	142.250.76.67	TCP	54	[TCP Dup ACK 7#1] 40910 → 80 [ACK] Seq=1 Ac
36	12.800305076	142.250.76.67	192.168.137.129	TCP	60	[TCP Dup ACK 8#1] 80 → 40910 [ACK] Seq=1 Ac
37	15.606619023	192.168.137.129	142.250.76.67	TCP	54	[TCP Dup ACK 11#1] 40882 → 80 [ACK] Seq=1 A
38	15.606920237	142.250.76.67	192.168.137.129	TCP	60	[TCP Dup ACK 12#1] 80 → 40882 [ACK] Seq=1 A
39	16.122301434	192.168.137.129	142.250.76.67	TCP	54	[TCP Dup ACK 21#1] 40894 → 80 [ACK] Seq=1 A
40	16.122645013	142.250.76.67	192.168.137.129	TCP	60	[TCP Dup ACK 22#1] 80 → 40894 [ACK] Seq=1 A

Capture:

- TCP handshake
- TCP stream

Follow TCP Stream

Right-click packet:

Follow → TCP Stream

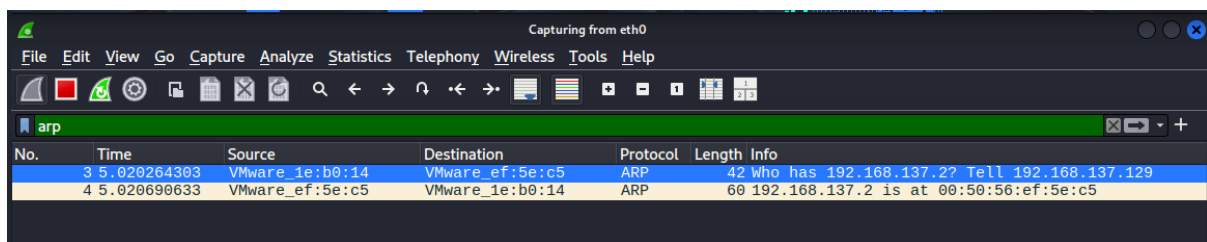
PART 5 — ARP Traffic Analysis

Apply ARP Filter

arp

Look for:

- ARP requests
- ARP replies
- MAC-IP mapping



No.	Time	Source	Destination	Protocol	Length	Info
3	5.020264303	VMware_1e:b0:14	VMware_ef:5e:c5	ARP	42	who has 192.168.137.2? Tell 192.168.137.129
4	5.020690633	VMware_ef:5e:c5	VMware_1e:b0:14	ARP	60	192.168.137.2 is at 00:50:56:ef:5e:c5

Capture:

- ARP request/reply

Risk Explanation

ARP spoofing may lead to:

- Man-in-the-middle attacks
 - Traffic interception
-

PART 6 — Password Auditing using John the Ripper

John the Ripper

Used for:

- Password auditing
- Hash cracking
- Dictionary attacks

Create Password Hash

1. MD5

`echo -n "password123" | md5sum`

```
(sakshi@kali)-[~]  
$ echo -n "Pass@word$98" | md5sum  
29c415ca2ae969fdebbde033850a5723 -
```

2. Save Hash

`nano hashes.txt`

Paste: 29c415ca2ae969fdebbde033850a5723

```
(sakshi@kali)-[~]  
$ nano hashes.txt
```

3. Run John

`john hashes.txt`

Purpose: Crack password hashes using John the Ripper.

```
(sakshi@kali)-[~]  
$ john hashes.txt  
Created directory: /home/sakshi/.john  
Warning: detected hash type "LM", but the string is also recognized as "dynamic-md5($p)"  
Use the "--format=dynamic-md5($p)" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "HAVAL-128-4"  
Use the "--format=HAVAL-128-4" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "MD2"  
Use the "--format=MD2" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "mdc2"  
Use the "--format=mdc2" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "mscash"  
Use the "--format=mscash" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "mscash2"  
Use the "--format=mscash2" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "NT"  
Use the "--format=NT" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD4"  
Use the "--format=Raw-MD4" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5"  
Use the "--format=Raw-MD5" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5u"  
Use the "--format=Raw-MD5u" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "Raw-SHA1-AxCrypt"  
Use the "--format=Raw-SHA1-AxCrypt" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "ripemd-128"  
Use the "--format=ripemd-128" option to force loading these as that type instead  
Warning: detected hash type "LM", but the string is also recognized as "Snefru-128"  
Use the "--format=Snefru-128" option to force loading these as that type instead
```

Use Wordlist

`john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt`

```
(sakshi@kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-md5 hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
Pass@word (?)
1g 0:00:00:01 DONE (2026-05-19 21:57) 0.7092g/s 7611Kp/s 7611Kc/s 7611KC/s Password1992..Pasarica@
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Show Cracked Passwords

john --show hashes.txt

```
(sakshi@kali)-[~]
└─$ john --show --format=raw-md5 hashes.txt
?:Pass@word

1 password hash cracked, 0 left
```

Capture:

- Hash file
- John cracking process
- Cracked password output

Cat ~/.john/john.pot

```
(sakshi@kali)-[~]
└─$ cat ~/.john/john.pot
$dynamic_0$29c415ca2ae969fdebbde033850a5723:Pass@word
```

PART 7 — Password Auditing using Hydra

Hydra

Hydra performs:

- Online password attacks
- Login testing
- Brute-force auditing

HTTP Login Test

hydra -l msfadmin -P /home/sakshi/wordlist.txt -vV -f ftp://192.168.137.133

Part	Meaning
-l	Username
-P	Password list
http-post-form	Login form

Part	Meaning
	attack

```
(sakshi@kali)-[~]
$ hydra -l msfadmin -P /home/sakshi/wordlist.txt -vv -f ftp://192.168.137.133
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
ng, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-19 09:01:54
[DATA] max 5 tasks per 1 server, overall 5 tasks, 5 login tries (l:1/p:5), ~1 try per task
[DATA] attacking ftp://192.168.137.133:21/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "msfadmin@" - 1 of 5 [child 0] (0/0)
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "admin" - 2 of 5 [child 1] (0/0)
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "sdewr764" - 3 of 5 [child 2] (0/0)
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "ad@m!78" - 4 of 5 [child 3] (0/0)
[ATTEMPT] target 192.168.137.133 - login "msfadmin" - pass "msfadmin" - 5 of 5 [child 4] (0/0)
[21][ftp] host: 192.168.137.133 login: msfadmin password: msfadmin
[STATUS] attack finished for 192.168.137.133 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-19 09:01:55
```

Capture:

- Hydra execution
- Password found

PART 8 — Secure vs Insecure Session Management

1. Insecure Session Example

HTTP Session

The image shows a Wireshark packet capture of an HTTP session. The packet list on the left shows a GET request from 192.168.137.129 to 192.168.137.133 on port 80. The packet details pane shows the request and response. The response is an HTTP 200 OK with a 'Set-Cookie' header: 'security=high; PHPSESSID=7e83bd5d407b339a477b83f9c1d79440'. The packet bytes pane shows the raw data of the response, including the cookie value in plaintext.

Problems:

- Session cookie sent in plaintext
- Easy interception

Secure Cookie

Set-Cookie: SESSIONID=abc123; Secure; HttpOnly; SameSite=Strict

PART 9 — Session Hijacking Concepts

What is Session Hijacking?

Attackers steal session tokens to impersonate users.

Common Techniques

Attack	Description
Session Sidejacking	Sniff session cookies
XSS-based Theft	Steal cookies via JavaScript
MITM Attack	Intercept traffic

Example Risk

Captured session cookie reused by attacker .

Prevention Techniques

Prevention	Benefit
HTTPS Everywhere	Encrypt traffic
Secure Cookies	Protect session token
Session Timeout	Reduce exposure
MFA	Additional security

Findings Section

1. HTTP traffic transmitted data in plaintext.
2. DNS queries revealed browsing activity.
3. Weak passwords were successfully cracked.
4. Session cookies lacked secure attributes.

Conclusion

The practical demonstrated risks associated with insecure protocols, weak passwords, and poor session management. Secure communication protocols and strong authentication mechanisms are essential to protect systems and user sessions.

Task 4 - Malware, System Security & Cloud Security

Practical Guide

Objectives

To study malware analysis, system hardening, and modern security defense mechanisms including cloud security concepts.

You will:

1. Study malware types
2. Prepare malware analysis documentation
3. Perform Windows/Linux hardening
4. Study:
 - Firewall
 - IDS/IPS
 - SIEM
 - Cloud Security
5. Compare offensive vs defensive security
6. Prepare report
7. Upload project to GitHub

Tools Used

Tool	Purpose
Strings	Extract readable strings
UFW	Linux firewall
Netstat	Network monitoring
Snort	IDS/IPS
Wazuh	SIEM platform

PART 1 — Malware Basics

What is Malware?

Malware means malicious software designed to:

- Damage systems
- Steal data
- Spy on users
- Disrupt services

Common Malware Types

Malware Type	Description
Virus	Infects files/programs
Worm	Self-spreading malware
Trojan	Fake legitimate software
Ransomware	Encrypts files for ransom
Spyware	Monitors user activity
Rootkit	Hides malicious processes
Keylogger	Records keystrokes

Malware Analysis Types

Analysis Type	Purpose
Static Analysis	Study without execution
Dynamic Analysis	Observe behavior during execution

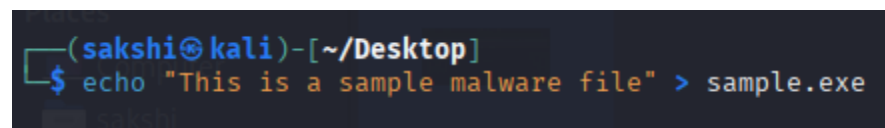
PART 2 — Static Malware Analysis

1. Strings Command

Extract readable text from files.

2. Create Sample File

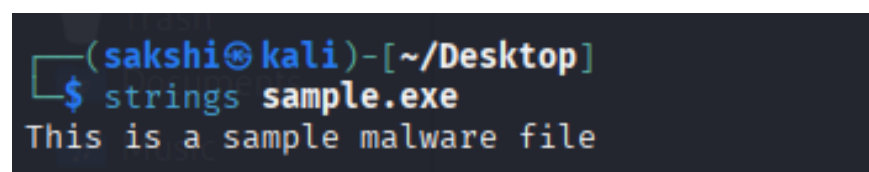
```
echo "This is a sample malware file" > sample.exe
```



```
(sakshi@kali)-[~/Desktop]
$ echo "This is a sample malware file" > sample.exe
```

3. Extract Strings

```
strings sample.exe
```



```
(sakshi@kali)-[~/Desktop]
$ strings sample.exe
This is a sample malware file
```

Capture:

- Sample file
- Strings output

File Hash Analysis

Generate SHA256 Hash

sha256sum sample.exe

Used for:

- File identification
- Threat intelligence
- Integrity verification

```
(sakshi@kali)-[~/Desktop]
$ sha256sum sample.exe
11c8001afe140c9cc8412a0ab9c40498b1f0283d6e2dc96ac4013d7d357b50e1 sample.exe
```

SHA256 hash generated successfully.

File Information Analysis

file sample.exe

Identifies:

- File type
- Architecture
- Executable format

```
(sakshi@kali)-[~/Desktop]
$ file sample.exe
sample.exe: ASCII text
```

Capture:

- File command output
 - SHA256 hash output
-

PART 3 — Dynamic Malware Analysis (Safe Demonstration)

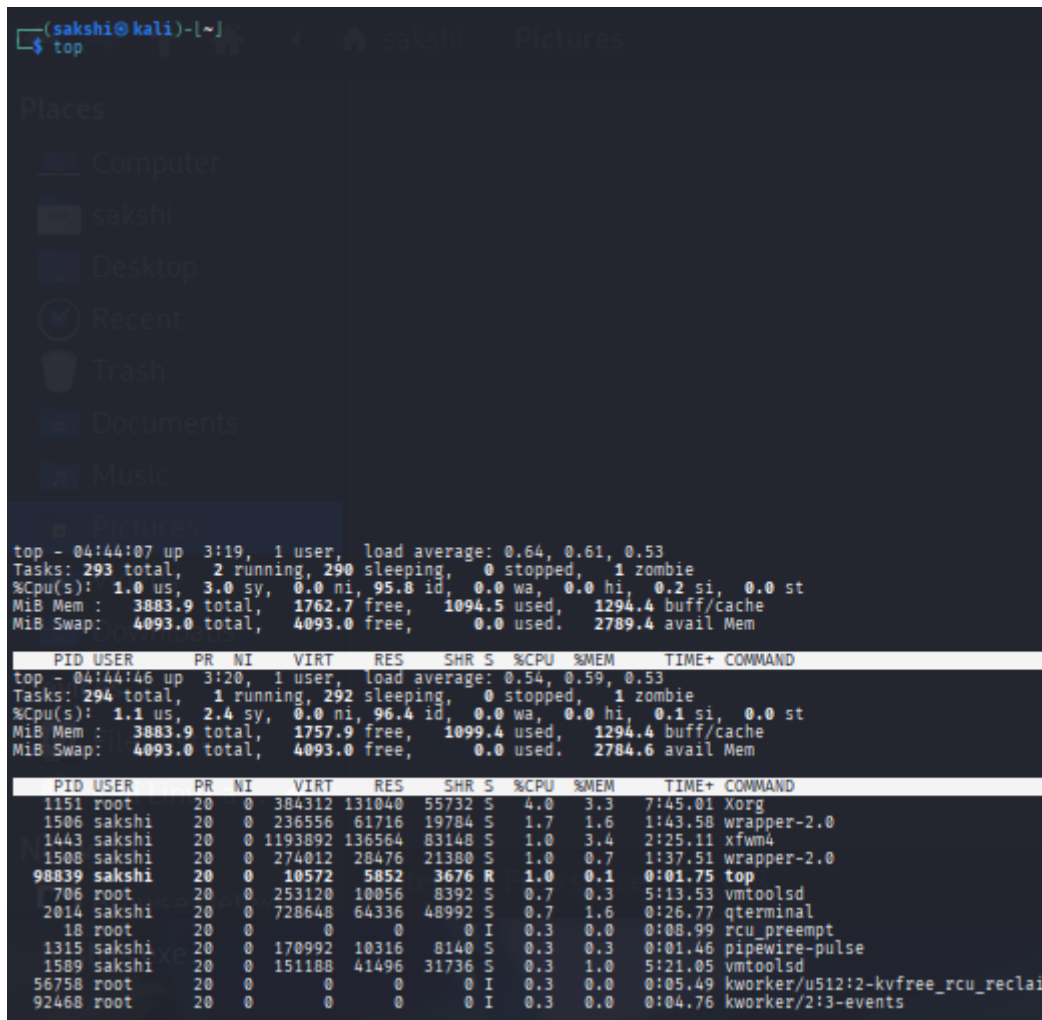
Process Monitoring

Monitor:

- Processes
- Network connections
- File changes

Monitor Running Processes

top OR htop



```
(sakshi@kali)-[~]
$ top
top - 04:44:07 up 3:19, 1 user, load average: 0.64, 0.61, 0.53
Tasks: 293 total, 2 running, 290 sleeping, 0 stopped, 1 zombie
%Cpu(s): 1.0 us, 3.0 sy, 0.0 ni, 95.8 id, 0.0 wa, 0.0 hi, 0.2 si, 0.0 st
MiB Mem : 3883.9 total, 1762.7 free, 1094.5 used, 1294.4 buff/cache
MiB Swap: 4093.0 total, 4093.0 free, 0.0 used, 2789.4 avail Mem

  PID USER      PR  NI   VIRT   RES   SHR  S  %CPU  %MEM    TIME+  COMMAND
 1151 root        20   0 384312 131040 55732 S   4.0   3.3   7:45.01 Xorg
 1506 sakshi    20   0 236556 61716 19784 S   1.7   1.6   1:43.58 wrapper-2.0
 1443 sakshi    20   0 1193892 136564 83148 S   1.0   3.4   2:25.11 xfwm4
 1508 sakshi    20   0 274012 28476 21380 S   1.0   0.7   1:37.51 wrapper-2.0
98839 sakshi    20   0 10572 5852 3676 R   1.0   0.1   0:01.75 top
  706 root        20   0 253120 10056 8392 S   0.7   0.3   5:13.53 vmtoolsd
 2014 sakshi    20   0 728648 64336 48992 S   0.7   1.6   0:26.77 qterminal
    18 root        20   0 0 0 0 I   0.3   0.0   0:08.99 rcu_preempt
 1315 sakshi    20   0 170992 10316 8140 S   0.3   0.3   0:01.46 pipewire-pulse
 1589 sakshi    20   0 151188 41496 31736 S   0.3   1.0   5:21.05 vmtoolsd
56758 root        20   0 0 0 0 I   0.3   0.0   0:05.49 kworker/u512:2-kvfree_rcu_reclai
92468 root        20   0 0 0 0 I   0.3   0.0   0:04.76 kworker/2:3-events
```

Monitor Network Connections

netstat -antp

Capture:

- Running processes
- Active network connections

```
File Actions Edit View Help
(sakshi@kali)-[~]
$ sudo netstat -antp
[sudo] password for sakshi:
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
PID/Program name
tcp        0      0 192.168.137.129:56126   199.232.105.91:443     ESTABLISHE
D 121337/firefox-esr
tcp        0      0 192.168.137.129:59800   34.160.144.191:443     ESTABLISHE
D 121337/firefox-esr
tcp        0      0 192.168.137.129:45868   151.101.1.91:443       ESTABLISHE
D 121337/firefox-esr
tcp        0      0 192.168.137.129:42522   199.232.105.91:443     ESTABLISHE
D 121337/firefox-esr
(sakshi@kali)-[~]
```

Suspicious outbound connection detected.

PART 4 — Linux Hardening Basics

Tool Explanation

Linux hardening improves system security.

Step 1 — Update System

sudo apt update && sudo apt upgrade -y

```
(sakshi@kali)-[~]
$ sudo apt update && sudo apt upgrade -y
[sudo] password for sakshi:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.9 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [116 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [258 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [910 kB]
Fetched 75.3 MB in 4min 35s (274 kB/s)
2185 packages can be upgraded. Run 'apt list --upgradable' to see them.
The following packages were automatically installed and are no longer required:
amass-common libgirepository-1.0-1 libsphinxbase3t64 python3-kismetcapturertladsb
curlftpfs libgpgme11t64 libsqlcipher1 python3-kismetcapturertlamr
firmware-ti-connectivity libgpgmepp6t64 libswscale8 python3-multipart
gir1.2-girepository-2.0 libhdf4-0-alt libteamctl0 python3-packaging-whl
libarmadillo14 libinstpatch-1.0-2 libtheora0 python3-pluginbase
libaudio2 libjs-jquery-ui libtsk19t64 python3-protobuf
libavc1394-0 libjs-underscore libudfread0 python3-pyinstaller-hooks-contrib
libavfilter10 libmongoc-1.0-0t64 libunibreak6 python3-pysmi
libavformat61 libmupdf25.1 libvdpau-va-gl1 python3-pysnmp4
libblosc2-4 libnet1 libwireshark18 python3-terminaltables
libbluray2 libogdi4.1 libwiretap15 python3-wheel-whl
libbson-1.0-0t64 libplacebo349 libwsutil16 python3-xlrd
libconfig-inifiles-perl libpocketsphinx3 mesa-vdpau-drivers python3-xlutils
libcrypt-dev libportmidi0 openjdk-21-jre python3-xlwt
libdisplay-info2 libpostproc58 openjdk-21-jre-headless python3-yaswfp
libdlt2 libqt5ct-common1.8 pocketsphinx-en-us python3-zombie-imp
libfuse2t64 libradare2-5.0.0t64 python3-bluepy ruby-unf-ext
libgav1-1 librubberband2 python3-click-plugins samba-ad-dc
```

Step 2 — Check Open Ports

sudo ss -tulnp

```
(sakshi@kali)-[~]
└─$ sudo ss -tulnp
Netid            State      Local Address          Foreign Address         State
(sakshi@kali)-[~]
└─$
```

Option Meaning

- t TCP
- u UDP
- l Listening ports
- n Numeric output
- p Process details

Step 3 — Enable Firewall

1. Install UFW

sudo apt install ufw -y

```
(sakshi@kali)-[~]
└─$ sudo apt install ufw -y
[sudo] password for sakshi:
Installing:
  ufw
Suggested packages:
  rsyslog
Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2051
  Download size: 169 kB
  Space needed: 880 kB / 61.2 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 ufw all 0.36.2-9 [169 kB]
Fetched 169 kB in 1s (152 kB/s)
Preconfiguring packages ...
Selecting previously unselected package ufw.
(Reading database ... 353580 files and directories currently installed.)
Preparing to unpack .../archives/ufw_0.36.2-9_all.deb ...
Unpacking ufw (0.36.2-9) ...
Setting up ufw (0.36.2-9) ...
Creating config file /etc/ufw/before.rules with new version
Creating config file /etc/ufw/before6.rules with new version
Creating config file /etc/ufw/after.rules with new version
Creating config file /etc/ufw/after6.rules with new version
update-rc.d: We have no instructions for the ufw init script.
update-rc.d: It looks like a non-network service, we enable it.
Created symlink '/etc/systemd/system/multi-user.target.wants/ufw.service' -> '/usr/lib/systemd/system/ufw.service'.
Processing triggers for kali-menu (2025.2.7) ...
Processing triggers for man-db (2.13.1-1) ...
```

2. Enable Firewall

sudo ufw enable

Purpose: Enable Linux firewall protection.

```
(sakshi@kali)-[~]
└─$ sudo ufw enable
Firewall is active and enabled on system startup
```

3. Allow SSH

sudo ufw allow ssh

```
(sakshi@kali)~$ sudo ufw allow ssh
Rule added
Rule added (v6)
```

4. Check Firewall Status

sudo ufw status verbose

```
(sakshi@kali)~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)
```

Capture:

- Firewall enabled
- Firewall rules

Step 4 — Disable Unnecessary Services

sudo systemctl list-unit-files --type=service


```
(sakshi@kali)-[~]
$ sudo systemctl list-unit-files --type=service
UNIT FILE                                STATE                                PRESET
accounts-daemon.service                 enabled                             enabled
apache-htcacheclean.service             disabled                           disabled
apache-htcacheclean@.service            disabled                           disabled
apache2.service                         disabled                           disabled
apache2@.service                        disabled                           disabled
apparmor.service                        disabled                           disabled
apt-daily-upgrade.service               static                             -
apt-daily.service                       static                             -
atftpd.service                          indirect                           disabled
auth-rpcgss-module.service              static                             -
autovt@.service                         alias                              -
avahi-daemon.service                   disabled                           disabled
blueman-mechanism.service               disabled                           disabled
bluetooth.service                      disabled                           disabled
capsule@.service                        static                             -
colord.service                          static                             -
configure-printer@.service              static                             -
console-getty.service                   disabled                           disabled
console-setup.service                   enabled                             enabled
container-getty@.service                 static                             -
cron.service                            enabled                             enabled
cryptdisks-early.service                masked                             disabled
cryptdisks.service                      masked                             disabled
dbus-org.freedesktop.hostname1.service  alias                              -
dbus-org.freedesktop.locale1.service    alias                              -
dbus-org.freedesktop.login1.service     alias                              -
dbus-org.freedesktop.ModemManager1.service alias                              -
dbus-org.freedesktop.nm-dispatcher.service alias                              -
dbus-org.freedesktop.timedate1.service   alias                              -
dbus-org.freedesktop.timesync1.service   alias                              -
dbus.service                             static                             -
debug-shell.service                     disabled                           disabled
display-manager.service                  alias                              -
dns2tcp.service                         generated                           -
```

Stop Service Example

`sudo systemctl stop apache2`

```
(sakshi@kali)-[~]
$ sudo systemctl stop apache2
[sudo] password for sakshi:
```

Step 5 — Password Policy

Edit password policy:

`sudo nano /etc/login.defs`

```
(sakshi@kali)-[~]
$ sudo nano /etc/login.defs
```

Recommended Settings

PASS_MAX_DAYS 90

PASS_MIN_LEN 8

PART 5 — Windows Hardening Basics

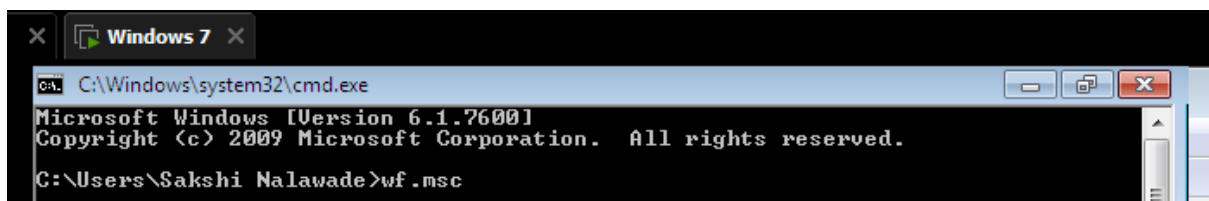
Important Windows Security Measures

Measure	Purpose
Windows Defender	Malware protection
Firewall	Block unauthorized traffic
Updates	Patch vulnerabilities
BitLocker	Disk encryption

Open Windows Firewall

Run:

wf.msc



Enable Windows Defender

Navigate: Windows Security → Virus & Threat Protection

Check Open Ports

CMD: **netstat -ano**

```

C:\Users\Sakshi Nalawade>wf.msc
C:\Users\Sakshi Nalawade>netstat -ano
Active Connections

```

Proto	Local Address	Foreign Address	State	PID
TCP	0.0.0.0:135	0.0.0.0:0	LISTENING	648
TCP	0.0.0.0:445	0.0.0.0:0	LISTENING	4
TCP	0.0.0.0:49152	0.0.0.0:0	LISTENING	364
TCP	0.0.0.0:49153	0.0.0.0:0	LISTENING	736
TCP	0.0.0.0:49154	0.0.0.0:0	LISTENING	820
TCP	0.0.0.0:49155	0.0.0.0:0	LISTENING	456
TCP	0.0.0.0:49156	0.0.0.0:0	LISTENING	464
TCP	0.0.0.0:49157	0.0.0.0:0	LISTENING	1624
TCP	192.168.137.138:139	0.0.0.0:0	LISTENING	4
TCP	192.168.137.138:49180	92.223.76.254:80	ESTABLISHED	820
TCP	:::1:135	:::1:0	LISTENING	648
TCP	:::1:445	:::1:0	LISTENING	4
TCP	:::1:49152	:::1:0	LISTENING	364
TCP	:::1:49153	:::1:0	LISTENING	736
TCP	:::1:49154	:::1:0	LISTENING	820
TCP	:::1:49155	:::1:0	LISTENING	456
TCP	:::1:49156	:::1:0	LISTENING	464
TCP	:::1:49157	:::1:0	LISTENING	1624
UDP	0.0.0.0:5000	***		820
UDP	0.0.0.0:4500	***		820
UDP	0.0.0.0:5355	***		1072
UDP	192.168.137.138:137	***		4
UDP	192.168.137.138:138	***		4
UDP	:::1:5000	***		820
UDP	:::1:4500	***		820

Capture:

- Windows Firewall
- Defender dashboard
- Netstat output

PART 6 — Firewall Concepts

What is Firewall?

A firewall filters incoming and outgoing traffic.

Types of Firewalls

Type	Description
Network Firewall	Protects network perimeter
Host Firewall	Protects single device
Web Application Firewall	Protects web apps

PART 7 — IDS/IPS Concepts

IDS vs IPS

Technology	Purpose
IDS	Detect attacks

Technology	Purpose
IPS	Detect and block attacks

Popular IDS/IPS Tools

Tool	Type
Snort	IDS/IPS
Suricata	IDS/IPS
Zeek	Network monitoring

Example Snort Installation

sudo apt install snort -y

```
(sakshi@kali)-[~]
└─$ sudo apt install snort
Upgrading:
  hwloc libhwloc-plugins libhwloc15 libze1

Installing:
  snort

Installing dependencies:
  libdaq3 libfastjson4 liblua5.1-2 oinkmaster snort-common snort-rules-default
  libestr0 liblognorm5 liblua5.1-common rsyslog snort-common-libraries

Suggested packages:
  rsyslog-doc rsyslog-pgsql rsyslog-elasticsearch rsyslog-hiredis rsyslog-kubernetes rsyslog-clickhouse | rsyslog-gnutls rsyslog-relp
  rsyslog-mysql rsyslog-mongodb rsyslog-kafka rsyslog-snmp rsyslog-docker rsyslog-openssl rsyslog-gssapi snort-doc

Summary:
  Upgrading: 4, Installing: 12, Removing: 0, Not Upgrading: 2047
  Download size: 5,720 kB
  Space needed: 20.8 MB / 61.2 GB available
```

Capture:

- Snort installation
- Snort service status

PART 8 — SIEM Concepts

What is SIEM?

SIEM = Security Information and Event Management

Functions:

- Log collection
- Threat detection
- Alert generation
- Incident monitoring

Popular SIEM Solutions

SIEM Tool	Description
Wazuh	Open-source SIEM
Splunk	Enterprise SIEM
ELK Stack	Log analytics platform

Example Wazuh Installation Research

Capture:

- SIEM architecture diagram
- Wazuh dashboard screenshots (research-based)

PART 9 — Cloud Security Concepts

Cloud Service Models

Model	Description
IaaS	Infrastructure as a Service
PaaS	Platform as a Service
SaaS	Software as a Service

Cloud Security Risks

Risk	Example
Misconfiguration	Public S3 bucket
Weak IAM	Excessive permissions
Data Breach	Sensitive data exposure

Cloud Security Best Practices

Practice	Benefit
MFA	Strong authentication
Encryption	Data protection
IAM Policies	Access control
Logging	Monitoring

Major Cloud Providers

- Amazon Web Services
 - Microsoft Azure
 - Google Cloud
-

PART 10 — Offensive vs Defensive Security Comparison

Offensive Security	Defensive Security
Finds vulnerabilities	Protects systems
Penetration testing	Monitoring
Red Teaming	Blue Teaming
Exploit development	Incident response

Example Tools Comparison

Offensive Tool	Defensive Tool
Nmap	Firewall
Metasploit	IDS/IPS
SQLMap	WAF
Hydra	MFA

Findings Section

1. Weak services were identified on the Linux system.
2. Firewall rules successfully reduced attack surface.
3. SIEM solutions improve centralized monitoring.
4. Cloud misconfiguration remains a major security risk.

Conclusion

The practical demonstrated malware analysis basics, system hardening techniques, and the importance of defensive security technologies such as firewalls, IDS/IPS, SIEM, and cloud security controls.
